FAVORITE HEARTS

Developer system specification

FUNCTIONS	CONDITIONS	PERMISSIONS

Version 1.0 | 19 October 2026 | Prepared for Vishwa Dassanayake and the implementation developer

This handbook describes the uploaded and hosted matrimony demo, explains its actual conditions and side effects, and translates the supplied Owner Decisions draft into an implementation specification. The original seven-page decision document is included at the end for traceability.

Reading key: CURRENT means observed in the supplied source. TARGET means required by the Owner Decisions draft, still provisional. PROPOSED means an engineering design suggested here, not an existing feature or approved business decision. OPEN means a decision is missing or contradictory. RETIRE means existing behaviour to remove from launch.

Important boundary: The hosted site is a public demonstration. It is not a working production account, identity, payment or database service. This report does not certify launch readiness. No platform changes or production integrations were made while documenting it.

Contents

1. Scope, evidence and how to use this handbook 3

2. Product boundary and architecture 4

3. Screen and navigation inventory 6

4. Actors, access and visibility 8

5. Account entry and profile preparation 11

6. Verification, invitations and candidate control 15

7. Discovery, shortlist and comparison 17

8. Requests, connections, access withdrawal and safety 20

9. Membership, payments and entitlements 22

10. Staff operations, retention, support and localization 24

11. Public website and legacy functionality 26

12. Proposed production data and operation contracts 30

13. Current action catalogue and code ownership 34

14. Conflict register and implementation gaps 37

15. Open decisions - do not silently guess 39

16. Developer acceptance-test catalogue 40

17. Build sequence, handover and operational gates 45

18. Source map, glossary and coverage index 47

Appendix A. Original owner decision document 51

1. Scope, evidence and how to use this handbook

1.1 Source baseline

Source	Evidence and authority
Uploaded platform	1. Final-Favorite-Hearts.zip; extracted root Favorite-Hearts-Integrated. Includes source, compiled dist, tests and historical handover.
Hosted preview	https://favorite-hearts-zip-preview-oct19.vishwad.chatgpt.site ; Sites version 1, public access confirmed on 19 October 2026.
Source commit	0caf5491117a5719488c3c398184d9e35958bcf7 - the source state packaged for this deployment.
Owner document	1. A Decision .pdf; title Favorite Hearts: Owner Decisions and Replit Prompts; draft v1, 19 October 2026; 7 pages. References below use D1-D7 for its original page numbers.
Code references	All source paths in this report are relative to the extracted project root. Function names identify the operative logic, rather than changing generated bundle line numbers.

The Owner Decisions draft takes precedence over conflicting demo behaviour and marketing copy for the target specification. Its own introduction makes all rules provisional until owner, lawyer and accountant approval; recommendations marked not yet decided remain unapproved. The Replit prompts are a proposed staged build process, not proof that those stages have been executed.

Do not resolve a missing decision by treating an old UI label as policy. Use the OPEN register in chapter 15. Source inspection was of the exact package deployed in this conversation; this was not a browser-by-browser usability audit. Generic UI primitives are inventoried as shared infrastructure; domain actions and visible controls receive explicit coverage.

1.2 Verified findings and limits

- A fresh static scan found 23 HTML files, 24 Join controls and 730 local asset/navigation references, with zero missing local targets. This checks file existence, not visual quality or successful remote service calls.
- Seven focused source assertions passed: verified free publication and shortlist allowance; unpaid send rejection; anonymous received-interest preview; contact hidden before acceptance; contact reveal after acceptance; both-party contact hiding when either plan expires; and the demo's 48-hour invitation lifetime. These ran against temporary copies with import extensions adjusted for Node's TypeScript support.
- docs/TEST-RESULTS.txt reports earlier DOM/logic tests for account entry, publication, permissions, invitations, ownership, promotions and privacy. Those archived results are historical evidence, not tests rerun for this report. The full test suite requires dependencies absent from this session.
- No real SMS, email, identity provider, bank reconciliation, database authorization, load test, backup restore or independent security review was exercised. No real mobile/Safari/Chrome visual certification is implied.

1.3 Developer reading order

Read chapters 2-4 for scope and access; chapters 5-11 for workflows; chapters 12-15 for the implementation plan, conflicts and decisions; chapter 16 for acceptance tests. Use the action catalogue and source index to locate the exact code. Read the attached Owner Decisions pages before implementing any money, privacy or verification rule.

2. Product boundary and architecture

2.1 What is included

The package combines a public marketing website with one matrimony member application. It supports self-managed profiles and profiles managed by a mother, father, guardian, family member or authorized person. The key journey is profile preparation, publisher verification, free publication, paid introductions, mutual acceptance and access to private contact details. Matrimony has no in-app chat. Dating is not included in the deployed member bundle. Launch horoscope calculations and birth-information workflows are out of scope under D1; the horoscope-importance preference remains.

2.2 Current runtime

Layer	Current implementation	Production consequence
Website	Static HTML, local CSS/JS, images and fonts. HTML templates assembled by Python.	Keep existing design and pages; update stale copy and metadata.
Member interface	React 19.2.0 and TypeScript/TSX bundled to a browser IIFE by esbuild 0.25.11.	There is no server-rendered member app or API in this package.
Styling	Marketing Tailwind 3.4.17 alias; member Tailwind 4.1.16, custom CSS and override files; Radix UI components, Lucide icons and Sonner notices.	Preserve separate page styling while consolidating only with an intentional migration.
Account entry	Module-level Map of login identifiers, passwords and actor IDs.	Replace completely with real authentication; passwords in memory are demo data.
Domain state	window.__heartsNetwork with accounts and interests; actions clone and mutate objects.	Replace client authority with authenticated backend operations and durable storage.
Uploads	Browser FileReader data URLs in the same in-memory network.	Replace with private storage, authenticated upload authorization and controlled retrieval.
Persistence	Theme, country and language preferences use localStorage. Product accounts and uploads disappear on reload or leaving the product document.	Persist user data on the backend; do not promise saved drafts until durable saving exists.
Deployment	dist is served as static output. Member entry is /matrimony/index.html.	Public availability of the preview is not a commercial launch authorization.

2.3 Source and build entry points

package.json defines npm run build -> scripts/build.mjs, npm start -> scripts/serve.mjs and npm test -> tests/integration.mjs. The supplied instructions recommend Node 22+ and Python 3.10+. npm ci restores the pinned dependencies. Serving the included dist needs no installation or rebuild.

The build compiles marketing Tailwind, runs website/scripts/build.py, recreates dist, bundles product/preview/entry.tsx, scopes CSS and rewrites root-relative links to explicit relative index.html paths. React dialogs, sheets, selects, popovers and alert portals are redirected into favorite-hearts-product. Never edit dist alone: rebuild from the maintained source, then retest and deploy the same source revision.

The current headers file declares nosniff, strict-origin-when-cross-origin, DENY framing, camera/microphone/geolocation disabled and a CSP allowing self, data images and Pexels images, with unsafe-inline for script/style. These are file declarations, not independently verified live response headers. A future camera/liveness service would require a deliberate policy change. The proposed Vite migration and Supabase backend come from D6; neither is already implemented.

3. Screen and navigation inventory

3.1 Member screens and overlays

Area	Controls and purpose	Key access / condition
Locale entry	Language, searchable country, Continue, theme and brand home.	Country must match the full supported entry-country list.
Signup / login / recovery	Identifier, password, confirmation, code, resend, back, password visibility, sample entry.	In-memory demo only; see chapter 5.
Profile wizard	Your role; essentials; story; privacy; review. Back, Continue, Save and finish later.	Dock hidden during onboarding. Existing members may jump sections and save early.
Discover	Search, location popover, preferences, sort, cards, compare, featured shelf, boosted group, organic list.	Current: completed onboarding, usable seat, target eligible.
Interests	Received, Sent, History; anonymous inbox for verified free members.	Paid membership reveals sender and enables responding.
Connected	Mutual and Shared details tabs; open photos/contact, end connection.	Current navigation requires paid membership.
Shortlist	Saved cards, search/filter/sort, compare and remove.	Current limits 3 / 20 / unlimited by access state.
Profile	Edit, cover, gallery, culture, contact consent, story, family, trust status and birth-detail shortcuts.	Manager permissions restrict editing after candidate joins.
Trust & access	Separate publisher/candidate checks, invitations, candidate response, manager permissions and takeover.	CURRENT role selector is a simulation, not authentication.
Membership	Current plan/expiry, purchase, pending notice, boost, payment history.	Candidate workspace only exposes takeover purchase under legacy policy.
Privacy & safety	Hide/resume profile, horoscope toggle, blocked list, report history, delete profile.	Candidate objection prevents manager resuming visibility.
Review workspace	Payments, identity checks, consent guidance, reports and editorial featuring.	CURRENT client-selectable reviewer; TARGET authenticated staff roles.
Contact us	WhatsApp, hotline, email, Instagram and Facebook tiles.	Current app channel values are empty and show Coming soon.

Area	Controls and purpose	Key access / condition
Horoscope	Birth data, tradition selection, requests, consents and fictional report.	RETIRE from launch except horoscope-importance preference.
Overlays	Full profile sheet; preference dialog; age picker; culture edit; compare; shared-values score; photo/selfie upload; boost; checkout; receipt review; report; birth details; action confirmation; delete.	Maintain focus, close behaviour, scroll access, readable errors and disabled busy states.

3.2 Navigation micro-behaviour

The bottom dock has Discover, Interests, Connected, Shortlist and Profile. Profile uses the uploaded cover as its icon when available. Counts reflect received interests (including anonymous previews), mutual connections and shortlist size; they are totals, not a true unread notification system. Counts above 99 display 99+. The More sheet contains language, theme, Trust & access, Horoscope, Membership, Privacy & safety, Boost, Contact and Review workspace, plus logout.

Attention counters currently cover invited candidate/rejected document, outstanding horoscope acceptance, unpaid membership without a pending payment, reviewed reports, and pending staff work. No push notifications, notification delivery service or durable read/unread records exist. Opening key overlays resets the app scroll position. Navigation closes the detail view and scrolls to top. Actor/seat changes refresh derived data; missing or unavailable selected profiles close automatically. Comparison selections are pruned when members disappear or introductions close.

The loading state offers Retry on failure. Actions show success/error toasts and busy states. Empty discovery offers wider/reset filters; empty shortlist returns to Discover. Empty received, sent, mutual, reports and payments states have explanatory copy. The source contains wording about conversations closing although chat is disabled; replace those references with connection terminology.

4. Actors, access and visibility

4.1 Target actor model

Actor	Allowed responsibilities	Must not gain
Anonymous visitor	Marketing pages, help, legal/support links and registration entry.	Any member photo, private contact, identity document or received-interest identity.
Self-managed member	Their own profile, verification, privacy, plan and interactions subject to gates.	Another person's private data without qualifying connection/access.
Manager	Up to 3 candidate profiles by default; own phone/document check; authorized profile administration.	Candidate identity badge from manager evidence; unlimited profiles; agency account in v1.
Invited candidate	Prove control of nominated channel, review profile, accept or decline.	Manager's unrelated profiles or payment/admin access.
Confirmed candidate	Privacy choices, permission changes, withdrawal/takedown and takeover.	Platform staff powers. Exact pre-takeover everyday capabilities need confirmation.
Revoked manager	No further access to the affected profile or its requests, connections and private details.	Previously granted URLs, subscriptions or cached API results continuing to authorize access.
Backup reviewer	Document review and moderation/report handling under separate MFA account.	Payment screens, payment APIs, payment storage or approval rights.
Owner	Payment reconciliation/approval, staff oversight and configured operational controls.	Unlogged privileged changes or bypasses based only on hidden UI.

TARGET rules above derive from D2-D5. The demo has only manager, candidate and reviewer seats; self-managed accounts map to candidate. Reviewer bypasses requirePermission and can approve payments. Role selection can be changed in the browser and does not isolate real users.

4.2 Current manager permission rules

Before a candidate joins, a non-revoked manager can edit and operate the profile subject to normal gates. On active candidate access, the candidate controls four booleans: edit, interests, privateDetails and horoscope. Edit gates profile, draft, cover, privacy, contact and photo uploads. Interests gates send, accept, decline, withdraw, reopen and ending connections. privateDetails gates that manager's viewing of shared contacts/socials/photos through the shared view. Horoscope gates birth management and comparison actions. Disabling horoscope permission clears pair comparison consents.

An active manager cannot change name, age, role, manager name or candidate email, and cannot delete the connected profile. CURRENT candidate access is deliberately restricted: no directory, profile edits or interests; only invitation, verification, permissions, manager removal, ownership request, consent withdrawal/restoration and eligible ownership payment. This restriction differs from a fully self-managed takeover and must not be mistaken for a complete candidate account implementation.

4.3 Current predicates, precisely

Predicate	Required conditions
hasPaid	plan is not essential AND planExpires exists AND expiry is strictly later than current time.
complete	onboarded; consentStatus not declined; trimmed name at least 2; age at least 18; city, occupation and education present; bio at least 20; contact phone valid; sharingAccepted true.
publisherVerified	Relevant publisher has phone=true and document=approved. Normally candidate for Self, manager for managed profile; a joined candidate with revoked manager becomes publisher. Selfie is not required by this predicate.
eligible	publisherVerified AND complete AND published AND me.visible.
unlocked(A,B)	Both accounts eligible; both paid; neither blocks the other; the pair's first stored interest is accepted.
canBrowse	Actor onboarded and neither accessDenied nor candidateWaiting nor candidateRestricted. Actor does not currently need publisher verification or publication to browse.
shortlistLimit	Paid -> unlimited; otherwise verified publisher -> 20; otherwise -> 3.
coverVisible	Viewer onboarded; target eligible; target cover toggle on and uploaded photo exists; no block; relation not declined/ended/blocked.

These predicates are CURRENT, not the final server policy. In particular, demo expiry on either side hides shared details from both sides; D6 explicitly discusses hiding for the expired member. Decide the other still-paid party's access before implementing the final policy.

4.4 Data visibility matrix

Data	Anonymous	Browsing member, no connection	Current qualified mutual connection	Target notes
Name, age, location, job, bio, education, marital status, height, faith, languages, values, hobbies, timeline, lifestyle	No member directory	Available for eligible target	Available	Optional sensitive fields need explicit consent and policy.
Family story, parents' names/jobs, sibling professions, income range	No	CURRENT visible before acceptance	Visible	Not private in this source. Confirm this deliberate exposure; label income self-declared.
Cover image	No	Only when target enables cover visibility	Revealed with shared access	Separate authorized or blurred derivative; no original leakage.
Four gallery images	No	Empty gallery / placeholder	Available	Maximum 5 total including cover; originals private.
Private phone, email, social links	No	Null / empty	Available when shared=true	D2 adds candidate restriction controls and manager + candidate contact attribution.
Incoming sender identity	No	Free verified inbox gets only opaque request key, age, job	Paid inbox identifies sender	Enforce server projection, not CSS blur. Avoid identifying metadata in URLs.
Birthplace and lagna	No	CURRENT if horoscope toggle enabled	Same	RETIRE birth sharing at launch.
Exact birth details	No	Hidden	CURRENT separate comparison consent required	RETIRE at launch.
Identity evidence and payment proof	No	Never a profile field	Never connection data	Subject and authorized staff only; backup cannot access payment proof.

Current viewNetwork constructs a filtered presentation but the full network remains in browser memory. It is not a security boundary. Also reviewReports is returned broadly and the access-denied path does not scrub every state field. Rebuild response allowlists from the server; do not serialize the Account object and remove a few known secrets.

5. Account entry and profile preparation

5.1 Signup, login, logout and recovery

CURRENT entry begins with country and language. Sri Lanka permits email or phone signup; overseas entry insists on email. Email identifiers are trimmed/lowercased; phone identifiers remove spaces, parentheses and hyphens. Phone format is optional + followed by 9-15 digits. Entry country selection is case-insensitive but must resolve to the supported list. TARGET D2 permits SMS or email signup by member choice; do not preserve the overseas-email-only limitation without approval.

Signup requires account-holder name of at least 2 characters, a new identifier, password of at least 8 characters, matching confirmation and adult/respectful-use agreement. A second domain check caps the supplied account name at 120 characters. Login rejects an unknown identifier or incorrect password. Both signup and login lead to simulated code verification. The code is 246810; no SMS/email is sent. Resend clears the code input and displays the same code; Change details returns to the form. Signup creates a member-UUID actor with a blank profile draft, selected country and account-holder name as provisional manager name.

Recovery requires an existing identifier, simulated code, and a new matching password of at least 8 characters. It returns to login after changing the Map value. The verified reset flag is cleared after use. Changing signup/login/recovery mode clears passwords and reset authorization. Theme changes preserve typed form values. Errors are visible in an alert region. Busy handling prevents duplicate account creation during the local operation.

Logout unmounts the member React tree and remounts entry; it does not erase the module Map or global network while that document remains loaded. Reloading or navigating back to the marketing document loses the product state. No real session revocation, cross-device login, durable recovery, password hashing or provider identity exists. TARGET: one Supabase authentication system, real code delivery and recovery, rate limits and secure server authorization; production must have no sample-code bypass.

5.2 Five-step wizard

Step	Fields / controls	Transition guard and result
1 - Your role	Self, Mother, Father, Guardian, Family member, Authorized person; manager name; optional candidate email; authority checkbox.	Managed profile needs name and authority; supplied email must be valid. Candidate confirmation itself remains optional for publication.
2 - Essentials	First name, age wheel 18-100, Man/Woman, marital status, country, district/city, occupation typeahead, education, height, income, faith, spoken languages.	Gender, name, location, occupation, education, integer adult age, marital status and height required. Country change clears city and contextual region. Sri Lanka uses district options.
3 - Story	Bio, up to 5 values, up to 6 hobbies, timeline, relocation, culture/lifestyle, optional parents/siblings and family story.	Bio at least 20 characters. Current form maxLength is 600 although its counter incorrectly says /500 and adds 1.
4 - Privacy	Private phone, optional email, sharing consent, up to 7 social links, horoscope-importance preference and legacy horoscope toggle.	Valid phone and sharing consent required; contact is saved before progression. Remove legacy birth-sharing toggle for launch.
5 - Review	Full scrollable summary of candidate, family, lifestyle, socials, contact and invitation details; adult/accuracy/serious-intent checkbox.	Final profile domain validation runs; saves onboarding and returns to Discover. This does not publish automatically.

Back changes the step, or returns home from the first step. New users cannot jump using step labels. Existing profiles start editing at Essentials and can jump all sections; Save and discover or Save and finish later validates and saves the whole edited profile. For a new profile, Save and finish later stores draft in memory. It is not durable saving. Failed saves keep the user in the form with a message. Some profile/contact changes use separate actions; production must avoid partial updates where profile succeeds but contact fails.

5.3 Profile field dictionary

Unless specified otherwise, CURRENT field limits describe source behaviour, not approved immutable business limits. Enforce required rules on the server as well as the form. UI maximums and code truncation are not equivalent to strong validation.

Field / object	Current type, limits and default	Visibility / details
name	String; trimmed 2 to less than 60 in base validator; UI permits typing 60.	Label says first name but code does not split full names; resolve 59/60 inconsistency.
age	Integer 18-100 at save; blank profile default 28.	Age wheel has 83 options and 44px increments. TARGET age 18+, manager declaration for managed candidates; date-of-birth handling remains a decision.

Field / object	Current type, limits and default	Visibility / details
gender	Man or Woman required.	Discovery maps to Men/Women; no dating genders in this flow.
role / manager	Six role values; manager up to 60; non-Self needs authority.	Shows Managed by role and manager name; self-managed hides manager name.
city / country	Location required; city capped 80; country capped 80.	Sri Lanka selection synchronizes contextual district. Domain profile validator does not independently enforce the full entry-country list.
job / education	Required; occupation UI/base max 100; education text cap 200.	Occupation suggestions allow custom input. Education accepts existing custom values.
height	Integer cm 100-230 in actual matrimony UI/save.	UI also shows feet/inches; generic helper elsewhere reaches 250 but is not this form's limit.
marital	Never married, Divorced, Widowed, Separated required.	Current filter omits Separated, even though entry permits it.
religion	Optional; default Prefer not to say; max 50.	Buddhist, Hindu, Christian, Muslim, Sikh, Jain, Other. TARGET optional where possible.
language	Comma-separated selected languages; max 80 when saved.	Searchable multi-select; existing values retained; long selections can be truncated mid-value. Prefer normalized values in production.
bio / family	Each up to 600; bio minimum 20.	Both visible on member profile. Instruct users not to place phone/exact address in bio; no actual detection exists.
values	Up to 5, each capped 25.	UI choices: Kindness, Family, Honesty, Growth, Learning, Independence, Faith, Creativity, Adventure, Balance.
hobbies	Up to 6; deduplicated; each capped 50.	Search full list, first 18 initially, up to 100 search results; add a custom value; remove chips.
timeline	Max 80; default Marriage in 1-2 years.	Ready for marriage, 1-2 years, 2-3 years, Open to discussing. Filter lacks last option.
relocation	Max 80; default Open to discussing.	Open to relocating; Prefer to stay where I live; Open to discussing.
familyInfo	Mother/father names max 80; jobs max 100; sisters and brothers each 0-12 entries, max 100 per profession.	All supplied details visible before acceptance. Changing count preserves first entries and drops removed entries.
incomeLevel	Optional, max 80; default Prefer not to say.	No income; below 50k; 50k-99,999; 100k-199,999; 200k-349,999; 350k-499,999; 500k-999,999; 1m+ LKR/month equivalent. TARGET label self-declared.

Field / object	Current type, limits and default	Visibility / details
candidateEmail / candidatePhone	Invitation contact; optional during initial profile; email validated.	Trust editing caps email at 150 and normalizes phone to 9-15 digits. Profile save itself only truncates candidatePhone to 40.
contact.email / phone	Email optional, valid if present, max 150; phone required, max 40, normalized format check 9-15 digits.	One shared contact object currently; no separate manager/candidate contact entities.
sharingAccepted / agreement / consent	Boolean; sharing required for completion; agreement required at save; manager authority declared separately.	Store independent versioned consent events in target; these booleans are not an audit history.
socials	Up to 7, each platform + URL; blank rows discarded.	Instagram, Facebook, LinkedIn, TikTok, YouTube, X, Website; private until shared.
context	Region, motherTongue, caste, communityOpenness, diet, smoking, drinking, childrenPlan, familyInvolvement; cleaned whitespace, max 80 each.	Optional, visible to browsing members; nonempty enumerated values validated. Caste is free-text, not inferred.
photo / gallery / coverPublic	One replaceable cover, four gallery slots; cover visibility false unless enabled.	JPEG/PNG up to 5 MiB, browser MIME check only. No individual gallery delete/reorder/cover promotion control was found.
horoscopeConsideration	Five fixed values; default Prefer not to say.	Matching essential; prefer matching but open; family prefers; do not care; prefer not to say. This field stays at launch.
horoscope	date, time, place, sign, note, accuracy, timezone.	Legacy optional feature, RETIRE at launch; see chapter 11 for current rules.
draft / preferences / publishedAt	In-memory object, filter preferences, first publication timestamp.	Publishing later does not replace existing publishedAt; not a fresh-post bump on every resume.

Context options: mother tongue includes Sinhala, Tamil, English and selected Indian languages/Other. Diet: Vegetarian, Non-vegetarian, Vegan, Pescatarian. Smoking/drinking: Never, Occasionally, Regularly. Children: would like, do not want, open to discussing. Family involvement: candidate-led, family involved, decide together. Community: open to any, prefer shared, open to discussing. Sri Lanka has all 25 districts; India has state/union-territory choices. Other countries allow region text.

Social normalization accepts supported usernames or full links. Usernames allow letters, numbers, underscore, dot and hyphen, up to 80 characters, and strip leading @. Known platforms get their URL prefix. Website/slash-containing inputs get https:// when needed. Final URLs must be HTTPS, no embedded user/password, at most 300 characters; other protocols are rejected. The code does not require a supplied full URL's host to match the chosen platform. Decide whether target validation should enforce domain matching and whether duplicate social channels are allowed.

6. Verification, invitations and candidate control

6.1 Publishing and checks

CURRENT profile creation and browsing do not require payment. Publication needs complete profile plus verified publisher phone and approved document. A candidate objection blocks completion. Publish sets published=true and visible=true and records publishedAt once. Unpublish clears both. Visibility resume requires completeness, verification and an existing published flag; it cannot independently publish an unpublished profile.

TARGET self-managed: identity document approval plus SMS phone verification before publication. Accepted documents are NIC, passport or driving licence. TARGET managed: manager's own document review and phone verification; not guardian selfie. The badge/explanation must say identity document reviewed and never government verified. The draft calls for Manager verified, Candidate confirmed and Candidate identity verified as three distinct badges; use explanatory copy to define the exact evidence behind each.

CURRENT trust checks are separate manager/candidate objects: phone boolean; document not_started/pending/approved/rejected; optional candidate selfie flag; note; submittedAt; temporary phone challenge. Start sets a ten-minute challenge. Confirm accepts demo code 246810 only before expiry and deletes the challenge. The attempts field is initialized but never incremented or enforced. Evidence submission requires own seat, completed phone, sample=true, and no pending/approved document. Reviewer approval/rejection needs pending status; rejection requires a reason and clears the selfie flag; rejected evidence can be retried.

There are two inconsistent selfie systems: trust.candidate.selfie contributes to the candidateIdentity badge, while the standalone verification.status feeds card Selfie reviewed labels and the verified-only filter. CandidateIdentity currently needs phone + approved document + selfie, while publication only needs phone + document. A sample liveness checkbox is not a real liveness check. D2 does not make selfie a launch publication requirement; decide whether any selfie feature survives and unify badge/filter semantics.

6.2 Invitation lifecycle

Event	CURRENT effect	TARGET difference
Save candidate contact	Manager only, managed profile, not active; valid optional email/phone; replaces contact; outstanding invitation reset to none.	Require nominated candidate contact different from manager; keep validated channel attribution.
Prepare/renew invitation	Manager, not already active, confirm=true, at least one valid channel; status invited; candidate consent pending; default permissions true.	Secure single-use token, 24 hours rather than demo 48; new link invalidates old; cap resends.
Candidate accepts	Candidate seat, unexpired invited state, own sample phone verified and explicit confirmation; sets active, candidateJoined=true, confirmed.	Require code delivered to nominated phone/email; no role-selector impersonation. Identity may follow later.
Candidate declines	Candidate seat and invited state; revoked, declined, visible=false, published=false.	Takedown and access revocation must be durable and auditable.
Candidate changes permissions	Active joined candidate and phone or selfie flag; sets four booleans.	Server enforces immediate revocation; remove horoscope permission at launch.
Candidate withdraws consent	Declined, unpublish/hide; accepted/pending interests become ended; horoscope consents cleared.	Candidate one-click takedown, audited; decide how it interacts with term and reactivation.
Candidate restores consent	Previously joined candidate, confirm=true; confirmed but remains hidden/unpublished.	Never auto-restore revoked manager or prior connections. New publication is separate.

The current invitation has no secret token, no binding to an external verified channel, no single-use token record, no manager-contact inequality check and no resend rate limit. A seat dropdown supplies the candidate actor. Validation conditions must be replicated as backend checks with a real authenticated identity and atomic token consumption.

6.3 Remove manager versus ownership transfer

CURRENT removeManager requires active candidate confirmation, revokes all manager permissions immediately and keeps candidateJoined. It does not change role to Self or by itself create a normal self-managed workspace. requestOwnership requires joined candidate, confirm=true, no prior ownership request; it immediately revokes manager, pauses/unpublishes, and requires a legacy LKR 1,500 receipt. Approval changes role to Self, clears manager, confirms consent, preserves membership expiry and leaves the profile hidden until separate verification/publication gates pass. Rejection leaves ownership requested, manager revoked and ad paused, with resubmission possible.

TARGET D2-D3 says candidate can take over by removing the manager, keeps paid time, and manager loses all profile access immediately. It does not authorize a takeover fee. Treat the fee/payment gate as a conflict, not a launch requirement. Confirm whether candidate identity review must precede republishing after takeover; manager evidence must never become candidate evidence. A manager with multiple candidates loses only the transferred profile, not automatically every profile. Payment history visibility after

takeover needs a precise policy because a receipt can contain the former manager's financial data.

6.4 Identity changes and revocation

CURRENT editing name, age, role, manager or candidate email resets trust checks; when consent is not confirmed it also resets access. Horoscope consents are removed. A linked candidate locks identity edits by manager. Candidate phone changes are not part of this identity-change comparison. An already-published flag may remain true even while reset verification makes the profile ineligible, so use explicit derived status in the UI. TARGET re-verification rules for name, date of birth, phone/channel and manager replacement need definition; preserve evidence history rather than overwriting it.

7. Discovery, shortlist and comparison

7.1 Directory eligibility and cards

CURRENT target profiles must be complete, publisher-verified, published and visible. The actor is excluded; blocks in either direction remove the target. Actor onboarding is sufficient to browse; verification is not required for this initial browsing. Managed candidate seats have no directory until takeover. Declined/ended pairs remain in the derived directory for history but are excluded from discovery. The report documents this distinction because filtering only the grid is not equivalent to hiding the underlying data.

Cards show cover/locked placeholder, first-name text and age, city/country, profession, management role, badges, two values, marriage intention, activity, shared values, shortlist, View profile, Send/Accept interest, and comparison checkbox. Received-interest labels appear only for paid viewers. Buttons disable for busy operations or already-existing non-received relationships. Featured and boost banners do not change eligibility or private-data gates.

Activity is simulated: some seeded accounts are always Online; others are Newly joined for less than 48 hours since createdAt, otherwise Recently active. There is no genuine presence or last-seen service. The profile readiness percentage is a UI heuristic: 0 absent, 25 draft, 75 onboarded, 90 with photo, 100 with standalone verified selfie. It is not the publication predicate and can contradict actual readiness.

7.2 Filter rules

Filter	Actual rule / edge condition
Text search	Case-insensitive substring across concatenated name, city, occupation and hobby tags. Query is not a full-text search service.
Gender	Women, Men or Everyone. Initial default Women; sample accounts set opposite gender; newly created profiles retain default unless changed.
Age	Inclusive min/max; integers, 18-100, min <= max. Default 24-35.
Location scope	Everywhere, Sri Lanka or Living abroad. Popover label Abroad maps to Living abroad.
District/country multi-select	Sri Lanka lists all districts; Abroad lists currently available directory countries. Empty selection means all in selected scope. Clear selection is temporary until Apply.
Explicit country/region	Separate advanced country and district/state choices. Setting country resets region and sets location Everywhere. Popover Apply resets explicit country/region to Any and sets selection arrays.
Faith / language / timeline	Exact faith/timeline; language substring within stored comma-separated string; Any disables filter.
Verified only	CURRENT standalone selfie review status, not document publisher verification or unified identity badge.
Context filters	Exact values for mother tongue, community openness, family involvement, children plan, diet, smoking, drinking; No preference disables. Missing target values fail a specific filter.
Caste	Optional normalized-whitespace, case-insensitive exact match; blank means no preference. No inferred caste. TARGET explicit data consent/removal and Prefer not to say.
Relocation / marital	Exact chosen value; No preference disables. Current marital filter excludes Separated option.
Horoscope offered	Checks legacy sharing flag; remove for launch unless redesigned around retained importance preference.
Sort / focus	Seven sort choices and four reflection priorities; described below.

All active filters combine with AND. Shortlist applies the same filters; a saved profile can therefore be absent from the visible shortlist while its ID still contributes to a count. Clear filters preserves gender and expands ages to 18-100 but otherwise uses defaults; Reset preferences restores default ages 24-35 and Women. The Reset button inside the modal changes the draft preferences until Save. Saved preference writes close the modal only on success.

There are no implemented education, occupation-specific, height-range or distance filters in the member preferences, despite those values/helpers existing elsewhere. Country lists are inconsistent: account entry supports a broad world list; profile/discovery options mostly use Sri Lanka, India, Australia, UK, Canada, UAE, US, New Zealand, Singapore and Other. A country shown by the available-country popover can be rejected by the smaller preference validator. Normalize this before launch.

7.3 Ordering and reflection algorithm

CURRENT orderProfiles sorts by Your priorities, Newest published, Shared values, age ascending, age descending, name A-Z or district A-Z. Ties break by name then ID. Newest uses publishedAt; missing timestamp acts as zero. District sort puts Sri Lankan districts first, then other/absent regions. Shared values counts common declared values; Your priorities uses reflection points.

Reflection is transparent rule matching, not AI, Gale-Shapley stable matching or a relationship-success prediction. Each positive area contributes 1, or 3 when it equals the selected focus. The areas are Shared values, Marriage timeline, Location & relocation, and Everyday lifestyle. Any overlap in values yields one positive event (not one per value); same timeline yields one; same country or both willing to relocate across countries yields one; each agreement on diet, smoking, drinking and children plans yields one. Maximum with lifestyle focus can therefore be larger than with another focus. Missing lifestyle information becomes unknown; differences become conversation questions, not negative penalty points. Caste, faith, income and photos do not add points.

Comparison lets the viewer select up to 3 profiles; at least 2 are required to open it. Removing profiles updates the comparison and closes it when fewer than 2 would remain. The overview names a highest-point starting conversation, describes ties, or says there is insufficient shared information. Each comparison shows strengths, differences, unknowns and a focus-specific question.

A separate card icon opens a Shared-values score: rounded 100 * intersection-size / union-size of case-insensitive declared value sets. Empty union displays Not enough information. This is Jaccard overlap, not compatibility. It conflicts with the sidebar statement No compatibility scores. Decide whether to retain a clearly labelled values-overlap percentage or remove it; do not advertise predictive accuracy.

7.4 Shortlist and promotions

Saving is private. Removing an existing saved ID is allowed directly. Adding requires onboarded actor, eligible target, no block, an open/nonclosed introduction and capacity. CURRENT limits: 3 before publisher verification, 20 after phone/document approval, unlimited paid. Decline removes both sides' shortlist entries; ending/blocking also removes both. Downgrading does not proactively truncate saved entries; future additions are blocked until below capacity. D1-D7 do not set shortlist quotas, so retaining these limits is OPEN.

CURRENT paid boost costs LKR 700 for 24 hours after approval, requires eligible published profile, allowed manager editing and no active boost at purchase. Managed candidates cannot buy a boost. Only one pending payment of any kind is accepted per profile. Approval validates eligibility again, requires exact amount and adds 24 hours to max(now, prior boostUntil). Boost never activates membership or private access. Editorial featuring lasts 7 days, reviewer-selected for eligible profiles, removable at any time. Featured takes display priority if also boosted; boosted-only cards follow featured, then organic. Filters remain in effect. D1-D7 do not authorize promotion pricing or inclusion at launch: keep both as OPEN scope items, not automatic launch additions.

8. Requests, connections, access withdrawal and safety

8.1 Current request state machine

Action	Preconditions	Result / side effects
Send	Different existing profile; neither blocked; sender eligible and paid; target eligible; explicit shareConsent; no existing pair record.	Creates pending record with UUID, from/to and timestamp. Target may be free and receives anonymous preview.
Accept	Actor is recipient of pending request; actor eligible/paid; sender eligible/paid; neither blocked; shareConsent true.	Status accepted, acceptedAt timestamp; shared access derived for both. Sending already records sender's acceptance/intent; receiver acceptance completes mutuality.
Decline	Actor is recipient of pending request; pair available and not blocked.	Status declined; remove each from the other's shortlist; no private reveal. Domain action itself does not require paid membership, although free UI cannot expose sender.
Withdraw sent	Actor is sender of pending request.	CURRENT deletes pair request entirely, so immediate resend is possible; TARGET cooldown handling differs.
End connection	Existing accepted pair and no block.	Status ended, clears horoscope consent, removes both shortlists; no future shared access.
Reopen	Only original declining recipient, pair declined and available.	Deletes declined record to allow fresh introduction immediately; does not accept.
Block	Different available pair, not already blocked by either side.	Add blocker entry, close relation as blocked if present, clear private sharing/comparison consent and both shortlists.
Unblock	Remove actor's block entry.	Does not restore accepted relationship; old blocked pair record can still prevent new sends.

CURRENT relation lookup uses the first matching record regardless of direction. It is not a durable event history or a concurrency-safe uniqueness policy. TARGET must keep pair identity and request attempts/history separate so a past declined/ended record does not block permitted retries forever.

8.2 Target quotas, cooldowns and acceptance

D1-D2: Starter allows 5 requests/day and 30/month; Premium allows 30/day despite advertised unlimited requests (fair use applies). Limits belong to the profile, not login. Sending and accepting require payment; unpaid verified members can receive but not identify senders. A request becomes a connection only when both agree; a decline reveals nothing. Withdrawal from a connection revokes both parties' future access and must be logged. After decline or withdrawal the same person can resend after 7 days. A maximum of 2 attempts per pair is RECOMMENDED ONLY, not decided.

PROPOSED implementation: evaluate authenticated actor, delegated permission, account/profile status, block relation, entitlement, pair state, cooldown and quota inside one transaction. Atomically reserve quota and create the request using an idempotency key. Return a stable denial code and an actionable message if any guard fails; do not consume quota for an unsuccessful request. A retry of the same successful request returns the previous result rather than a second request. These transaction mechanics are recommended engineering, not implemented functionality.

OPEN: timezone and daily reset; calendar month versus billing month; whether failed/withdrawn sends restore quota; whether reverse-direction requests share cooldown; whether 7 days applies to cancelling a still-pending send as well as ending a connection; whether sender must remain paid when recipient accepts; and handling simultaneous crossed requests. Resolve explicitly in chapter 15 before coding quota counters.

8.3 Privacy after acceptance

TARGET shares supplied manager and candidate contact details/social handles by default, with candidate privacy restrictions. Candidate phone on a managed profile can be unverified and must say not verified by candidate. Shared access for unconfirmed candidates is explicitly a high-risk provisional owner rule requiring lawyer review, manager permission attestation, exact disclosure logging and candidate takedown (D2). This handbook records the rule; it does not assert that it is legally approved.

CURRENT stores a single contact phone/email and social list, so cannot accurately express separate manager/candidate disclosure or per-field restrictions. Target needs contact ownership, verification state, visibility selection and versioned disclosure decisions. Redact data before serialization and authorize each original photo fetch. A pending, declined, withdrawn or blocked pair must not obtain private data through API, image URL, search index, export or browser preload. Previously copied information cannot be recalled; explain this before sharing.

8.4 Reports and moderation

CURRENT Report opens from a profile. Categories are Suspicious profile or scam (default), Harassment or pressure, False identity, Candidate consent concern, Inappropriate content and Other concern. Additional detail is optional, capped at 150 characters in the dialog. Block this member instead closes the report dialog and opens a separate block confirmation; it does not submit an unsent report. Submission needs a different unblocked member, reason at least 3 characters and no other Open report by that actor for the same profile; stored reason is capped 500. Reporting is separate from blocking and does not hide the target automatically. Reviewer marks Open -> Reviewed with a reviewedAt time. Reports from all accounts appear in the demo queue; member report history uses targetName fallback Profile no longer available. There is no investigation outcome, suspension, appeal or automatic threshold engine.

TARGET D3: serious categories explicit content, minors, threats and scam auto-hide content after 1 report. Other categories hide after 3 reports from different verified members. Staff review every auto-hide promptly, restore wrongly hidden content, and address repeated false reports. Photos otherwise appear immediately and are reviewed on report; a document reviewer may glance at cover. Exact report target (photo versus whole profile), serious-report submitter eligibility, what verified means, and threshold reset after restoration remain OPEN. Store category as a stable code, not a free-form concatenated reason; count distinct eligible reporters and prevent replay/race duplication.

TARGET pause/hide may be chosen any time. Engaged or married hides profile AND ends plan, with explicit forfeiture warning. Suspension for rule breaches loses remaining time per the draft. These status/plan transitions do not exist in the demo and need authorized backend operations, audit history and carefully worded confirmations. The minors-reporting operational procedure and applicable obligations require legal review, not invented automatic actions.

9. Membership, payments and entitlements

9.1 Target catalogue - provisional owner values

Plan	Term	Request cap	Sri Lanka	Diaspora
Starter	1 month	5/day and 30/month	LKR 3,000	USD 20
Premium	3 months	30/day fair-use cap	LKR 8,500	USD 55
Premium	6 months	30/day fair-use cap	LKR 15,000	USD 100

Free verified publication and free browsing remain separate from subscription. Each profile has its own plan. Money must use integer minor units with currency and immutable price version. Do not determine local/diaspora solely from nationality or NIC. Member selects residence; owner compares payment source and verified evidence, and mismatches are flagged for human review rather than rejected automatically. A NIC does not prove residence. No live provider availability or legal/tax conclusion has been verified by this report.

9.2 Current purchase workflow

The member app has free essential, matrimony at LKR 2,990/30 days, boost at LKR 700/24 hours and ownership-transfer at LKR 1,500. Marketing separately shows Essential/Signature/Premier at LKR 3,000/5,000/8,000 and USD 29/49/69. Both old catalogues conflict with D1. The member app has no request quotas, currency selection, price versions, upgrade/renewal windows or actual payment references assigned by server.

Checkout displays sample beneficiary, unconfigured bank/account, price and bank-transfer -> upload -> approval steps. It explicitly says not to transfer money. Users can download/use a sample PDF receipt and populate a demo reference. A real selected file is accepted only by browser checks: JPEG, PNG or PDF up to 5 MiB, reference at least 3 characters (UI max 100). Only one pending proof of any purchase type per profile; previous approved/rejected submissions remain in history. Data URLs, filename, MIME, reference, amount, plan, timestamp, pending status and note are stored locally. No bank statement is queried.

The all-account queue includes owner profile ID and name for each proof, pending first, then chronological timestamp. Review opens the evidence link, accepts a note, and permits approve/reject only while pending; rejection needs reason. A normal membership approval sets plan and 30-day expiry from approval time. Duplicate sequential review is refused, but there is no database transaction/concurrent replay protection. Current approval does not fully validate normal membership amount against a server-side price. Special boost and transfer branches require exact legacy amounts.

9.3 Target payment state machine

Stage	Required behaviour
Quote and selection	Resolve profile, residence pricing, plan and price version; show exact amount/currency, duration, quotas, refund terms and any forfeited days.
Payment instructions	Display only owner-supplied approved bank/SWIFT/provider details; generate unique reference associated with the relevant profile and payment.
Proof submitted	Authenticate uploader; validate file; store private proof and pending case. Upload alone grants no entitlement.
Owner reconciliation	Owner checks actual bank/Wise/provider statement against reference, amount, currency and transaction; reviews residence mismatch flag. A receipt image alone is insufficient.
Rejected	Record immutable reviewer/time/reason; notify member with correction path. Resubmission should preserve original evidence/history.
Approved	In a transaction, lock pending record and applicable profile entitlement; verify approval identity and unique settlement; create one entitlement event; set approved; enqueue notification.
Duplicate approval	Same result or explicit already-reviewed outcome; never another term, quota reset, boost or refund. Test simultaneous reviewers/clicks.
Dispute/refund	Record reason, payment link, authorization and result; entitlement consequence depends on approved rule. No final dispute suspension policy is specified yet.

Only owner approves payments. Backup has no payment API or storage access; hiding the tab is insufficient. Real reconciliation data and unique bank/provider transaction identifiers must prevent the same transfer being reused across profiles/submissions. Keep immutable logs; do not overwrite a historical approval with an unexplained new status.

9.4 Upgrade, renewal and expiry conditions

D1-D2: no automatic renewal. Only Starter -> Premium replacement is explicitly allowed while active; it starts immediately on approval, discards unused days, and must disclose exactly what is lost before payment. Active downgrade blocked. Same-tier renewal allowed only in last 7 days; new term counts from approval date even after expiry. Recompute eligibility on approval as well as quote because time may have passed. Define whether approval outside the allowed window invalidates an earlier eligible submission.

D2: expiry removes that member's contact/social visibility, including existing connections, with a clear advance warning of date and hidden information. Connections stay on record and reappear on renewal. Grace access for up to 3 days while renewal proof is pending is RECOMMENDED, NOT DECIDED. Do not silently activate it. Decide photo access on expiry separately; the draft explicitly names contacts/socials while the demo locks all shared details bilaterally.

D4: no refund after activation except duplicate payments, mistaken payments and service failures; show this on pricing/checkout and obtain acknowledgment. Do not interpret the draft as settled legal wording. Accountant/lawyer review and final legal operator details remain gates. The draft mentions international transfer to USD account, Wise/PayPal-style manual payments; these are intended channels, not confirmed working integrations. Do not invent credentials, bank numbers or receiving capability.

10. Staff operations, retention, support and localization

10.1 Review workspace and moderation controls

CURRENT reviewer dashboard summarizes pending payment proofs, pending manager/candidate identity checks across all accounts, the selected account's pending candidate consent and open reports. Payments queue is cross-account, fixing the older single-account visibility problem. Identity queue shows separate manager/candidate outcomes; the sample retry action uses a fixed unclear-document reason. Consent tab correctly instructs that reviewer cannot accept on candidate's behalf. Reports can only be marked Reviewed; no implemented severity triage, hide/restore, suspension, sanctions or escalation. Featured profiles tab toggles seven-day featuring.

TARGET owner and one trusted backup each have separate accounts and backend-enforced two-step login. Backup handles documents and reports only, signs confidentiality agreement and is revoked immediately on departure. Payment review belongs solely to owner. A recovery procedure for lost owner MFA device must exist without creating an uncontrolled backdoor. Review service expectation is within 48 hours for documents/payments. Add owner controls to pause new signups and/or document submissions when overloaded, show honest queue messaging, and keep existing member access policy explicit.

The prototype provides no secure owner/backup distinction, staff provisioning, operational queue pause or admin recovery workflow. All staff actions need actor, role, object, timestamp, reason and before/after or event reference; no sensitive document contents in generic logs. Staff can review reported photos but should not receive unrelated private galleries as a default dashboard payload.

10.2 Retention and deletion

Data / event	TARGET draft rule	Implementation or unresolved detail
Approved verification document	Delete automatically 90 days after approval; retain only document type, reviewer, date, decision after the retention period.	The text also says after approval keep only metadata; clarify whether raw files remain for 90 days or are deleted immediately. No job exists in current demo.
Rejected verification document	Same 90-day limit.	Define anchor: rejection date versus upload date; repeated submissions need per-file deadlines.
Member account deletion	Profile disappears immediately; delete profile text, photos, contacts, socials and documents.	This immediate document deletion conflicts with same-limit wording for deleted members' documents. Resolve; do not silently keep identity evidence.
Limited retained records	Payments, reports/blocks, staff audit and scrambled email/phone for 6 months.	Accountant must confirm payment-retention duration; define retention anchor, minimum fields and lawful purpose.
Payment records	Separate from profile, without photos or identity documents.	Minimize personal data; proof images may require their own retention rule and access category.
Backups / providers	No exact window specified in draft.	Define deletion propagation, restored-backup deletion replay and provider-log retention before promising erasure.

PROPOSED banned-contact matching should use keyed cryptographic digests and controlled key access, not plain unsalted hashes or reversible display encodings. This is an engineering proposal for the draft's scrambled form, not a legal conclusion. Limit retention to the approved purpose and duration. Deletion jobs need run ID, start/end, success/failure counts, object references and retry results without exposing document data. Failed deletes need alert and retry, and logs must not recreate deleted sensitive information.

CURRENT deleteProfile requires exact DELETE, closes/removes pair relationships, removes shortlist links in other accounts, and resets the actor's profile/payment/uploads to initial state. It leaves an account record keyed to the actor and the login Map intact. Other users' reports can retain a fallback target reference. There is no true account deletion, provider deletion, anonymization, retention job or export. Target must distinguish close profile from delete authentication account, particularly when one manager owns several profiles.

10.3 Official support and contact channels

Public website currently lists hello@favoritehearts.com and +94 76 676 9894, daily 08:00-22:00 Sri Lanka time. Member-app support constants are all empty. Public pages include WhatsApp/email links and social links, some of which are searches rather than confirmed official accounts. Do not assume these are approved operational contacts merely because they are in source.

D4 requires new dedicated SIM, phone, email and WhatsApp Business with two-step verification; official numbers displayed and staff never ask for passwords or codes. Identity documents must be uploaded only through the secure form, never WhatsApp/email. Support hours and the 48-hour review promise are different concepts. No support ticket backend or in-app chat is implemented; a contact link opening another application is not a submitted support case.

10.4 Languages, themes and accessibility

CURRENT member locale offers English, Sinhala and Tamil, with partial text-node translation via MutationObserver. It skips scripts, styles, textareas, inputs, options and data-no-translate nodes. Many longer paragraphs, form options, placeholders and accessible names are untranslated. Member-entered text is not translated. Storage keys fh-language and fh-country are separate from marketing fh-visitor-preferences. Marketing preferences store English/Sinhala and country; Sinhala selection currently does not translate the marketing content. These two preference systems are not synchronized.

TARGET English and Sinhala complete at launch; hide Tamil entry points but keep translations for later. Export copy with stable key, English, Sinhala, context/screen and reviewer status (the draft explicitly requests English/Sinhala columns). Include errors, emails/SMS, legal consent, placeholders, aria labels and notification text, not only visible headings. A native Sinhala reviewer approves language; lawyer reviews legal translations; designate authoritative legal language.

Theme is light/dark for account entry and member app, remembered in fh-matrimony-theme. Public marketing adapts header colour to underlying light/dark/photo sections rather than sharing the exact member theme state. Accessibility work must verify keyboard-only navigation, visible focus, readable contrasts, labels/errors, reduced motion, modals with internal scrolling, safe mobile viewport heights and 200% zoom. Current Radix components and ARIA labels help but are not a complete accessibility audit.

11. Public website and legacy functionality

11.1 Marketing route catalogue

Route	Content / purpose
/contact/	Contact us.; WhatsApp Support; Quick support & safety; Email us
/help/	Good questions. Thoughtful answers.; Getting started; Profiles & family; Introductions
/	Your person. Your forever.; Find your person. Build your forever.; We are love scientists.; Make room for your next chapter.
/labs/	We are love scientists.; Understanding people. Building lasting love.; The lab.; Existing Scientific Literature
/mission/	We want to make life less lonely; By bringing people together to build happy families; A shared future. Human values.; Be yourself.
/newsroom/a-first-conversation/	A first conversation that feels like you.; Begin with something real; Ask one question at a time; Make the next step mutual
/newsroom/a-thoughtful-beginning/	A shared future starts with a thoughtful beginning.; Our purpose; A choice that belongs to you; Get to know us
/newsroom/across-borders-on-the-same-page/	Across borders, on the same page.; Discuss what home means; Talk about the practical details; Build a realistic next step
/newsroom/an-honest-profile/	A thoughtful introduction starts with an honest profile.; Describe your actual life; Be clear about intentions; Share with care
/newsroom/before-marriage/	The little things worth talking about before marriage.; Think beyond the big occasion; Make room for differences; Keep the conversation open
/newsroom/belonging-across-borders/	Belonging, wherever life takes you.; A broad idea of home; Tradition and personal choice; What we hope to contribute
/newsroom/beyond-the-checklist/	Beyond the checklist: what does a shared life look like?; Start with an ordinary day; Name what matters to you; Leave room to learn
/newsroom/family-and-your-voice/	Family can be part of the journey. Your voice comes first.; Share the support you want; Keep expectations visible; Keep consent at the centre
/newsroom/	What’s new with Favorite Hearts.; A shared future starts with a thoughtful beginning.; The experience we want to build: matrimony with more heart.; Respect is part of every introduction.
/newsroom/matrimony-with-more-heart/	The experience we want to build: matrimony with more heart.; Start with intention; Make the important things clear; Keep people at the centre
/newsroom/respect-in-every-introduction/	Respect is part of every introduction.; Let a conversation be a choice; Share personal information carefully; Listen to discomfort
/pricing/	Find your person. Choose your beginning.; Three ways to begin.; Essential; Signature

Route	Content / purpose
/privacy/	Privacy Policy; About this policy; Information you share; Browsing and technical information
/security/	A little care. A safer connection.; Keep your information in your hands.; Keep access private; Check before you click
/terms/	Terms & Conditions; Using this website; Who the website is for; Current and planned features
/trust-and-safety/	Good connections. Respectful beginnings.; Respect is part of every introduction.; Choice comes first; Be clear about your role

These are 21 marketing pages (including ten newsroom articles), plus member entry and 404 = 23 HTML files. Paths accept the explicit index.html file form used by the exported build. Redirect definitions map /approach/ to /mission/, /explore/ to /labs/, /journal/* to /newsroom/ and /safety/ to /trust-and-safety/. Redirect/header enforcement depends on hosting; the static link scan does not prove redirect behaviour.

11.2 Public interactions and micro-features

Surface	Current behaviour
Shared menu	Full navigation overlay toggles aria-expanded, inert background and scroll lock; Escape closes/returns focus; Tab wrapping; links close menu; reduced-motion-aware close timing.
Header	Scroll/resize/load/pageshow measures whether header crosses photo, dark or light section and changes surface classes.
Join / Get started	All 24 .start controls resolve the configured registrationUrl from the site's asset-root path, including nested articles; go to member entry. If no route configured, shows explanatory contact dialog.
Generic/social dialog	Unknown data-page or unconfigured social controls show information/contact dialog. Close button, Escape through native dialog, and outside-bound click close it.
Visitor preferences	Footer opens optional language/country dialog; never auto-opens, even legacy ?welcome=1. Saves local preference and emits fh:preferences; pricing responds to country.
Landing reviews	Three explicitly sample reviews (Nethmi/Kavindu, Anjali/Dilan, Tharushi/Sameera); rotates every 7 seconds only in viewport, visible tab and not paused/hovered; keyboard/swipe and Pause/Play. Focus/reduced motion pause rotation. RETIRE fictional testimonials before live launch.
Mission	Exclusive accordion, principles carousel with keyboard/drag, scroll-driven numbers and decorative drawn arrow. Reduced-motion fallbacks.
Labs	Six advice articles; first three shown, All posts expands remaining, Show fewer collapses and moves focus appropriately. Research headings describe an ambition, not implemented research/AI features.
Newsroom	Ten editorial articles; category and case-insensitive search across title/category/body; first three matches; Show more/less; empty/reset; Our Stories has honest no-real-stories message.
Help / FAQ	Category filtering and all-query-word search over question/answer text; hides empty groups; counts results; one answer open at a time; reset and focus return.
Pricing	LKR/USD toggle based on stored visitor country; old plan values; no direct payment. Responsive horizontal cards, reachable snap positions, dots, keyboard/drag and resize recalculation.
Contact / resource pages	Exclusive FAQ disclosures; contact links; section reveal animations; security/resource carousels manage their own indicators independently.
Articles / images	Static text, related article links, on-error stock-image fallback where provided. Some images can make external Pexels requests.
Shared motion	IntersectionObserver reveals and decorative drawings once; no-observer/reduced-motion fallback shows content.
Legal pages	Static section links, website-only policy scope. They do not describe the target production account service yet.

11.3 Required content corrections

Pricing and Help currently state both sexes must pay to publish, conflicting with free verified publication. Pricing has obsolete Essential/Signature/Premier and proposed human guidance/support services. Terms and Privacy say registration, matching, verification and payments are unavailable, even though the demo navigation now enters simulated flows. Replace them with accurate prototype context now if maintaining the demo publicly, and approved production terms when launching; this report itself does not edit the site.

Privacy describes a temporary session flag and welcome-screen behaviour inconsistent with the current footer-only preference controller. The member source still labels the now-public preview Private test. Public contact values differ from empty app support. The configured canonical siteUrl points at an earlier integrated-matrimony host rather than this deployed preview. The member entry has noindex,nofollow and website indexable=false; public access is not the same as search indexing. Reconcile metadata, sitemap, canonical and social images for the real launch domain, not by automatically removing noindex from the demo.

Remove fictional profiles/sample receipts from production data and sample testimonials from production marketing. Claims of research, surveys, behavioural analysis or compatibility prediction must match real evidence; headings alone do not prove those systems exist. No analytics, marketing email opt-in or newsletter backend was found in the inspected website scripts. Registration action on pricing currently does not carry selected plan into member checkout.

11.4 Legacy horoscope - document, then exclude from launch

CURRENT birth fields validate date format/past date, time HH:MM, timezone and exact/approximate/unknown accuracy. Readiness requires valid real past date, time, birthplace, valid timezone and exact or approximate accuracy. Unknown time cannot satisfy readiness. The save validator is looser than birthMissing's calendar round-trip check. Both profiles must enable sharing. Request requires paid/eligible mutually connected pair, sender horoscope permission, sender birth readiness, supported tradition and no existing comparison. It does not require receiver's birth details before request; receiver must complete them before consent. This differs from older assumptions that both birth records are required before sending.

Traditions are Ashta Kuta, Tamil Porutham and Sri Lankan Porondam practitioner review. Request sets sender consent true and recipient false. Acceptance requires explicit confirmation of own birth details. Both consents and complete records produce ready_for_calculation. Editing birth details after own consent resets both consents. Disabling sharing, revoking permission or ending/blocking connection clears the comparison. Withdraw removes it. Exact birth fields reveal only with both consents and permission; birthplace/lagna can appear earlier when sharing enabled.

The report is a fixed fictional 24/36 Ashta Kuta chart regardless of selected method or birth data; factors are 1/1 Varna, 2/2 Vashya, 3/3 Tara, 2/4 Yoni, 3/5 Graha Maitri, 5/6 Gana, 0/7 Bhakoot and 8/8 Nadi. It is not a calculation. Launch removal must cover navigation, profile tab, birth dialog, filter, share toggle, permission, notification count, sample controls and all claims, not just hide one page. Keep only horoscopeConsideration.

11.5 Legacy and unreachable code warning

Base domain/matrimony modules still contain historical request/review, conversation and consent actions. applyNetwork explicitly rejects chatStart/message/chatEnd and legacy request/requestReview/demoReply/demoMessage/demoIncomingRequest, and directs requestConsent/candidateConsent through Trust & access. Do not implement old actions simply because they remain in a source file. The generic profile-options module contains dating-name, pets and illustrative distance helpers that are not active matrimony features. Score values on seeded profiles are not used as a launch matching algorithm.

12. Proposed production data and operation contracts

This chapter is a PROPOSED design to implement the draft, not a claim of an existing database, API, deployed stack or finalized provider capability. D6 requests incremental Vite/TypeScript for the member app, retained public HTML/styling, Supabase staging/production separation, versioned SQL migrations, row-level and storage policies, and a notification outbox. D7 names Resend and server-validated Turnstile. Provider setup, costs and availability must be verified during implementation.

12.1 Suggested records and invariants

Record	Essential fields / relationships	Invariants and protection
Account	Auth user ID, normalized verified channels, locale, status, createdAt.	Identity provider owns credentials; profile and account are not interchangeable.
Profile	Candidate ID, owner/account association, display fields, adult declaration, status, first publishedAt.	At most approved manager capacity; no public contact/document fields.
Manager membership	Profile, manager account, role, permission set, granted/revoked time, authority evidence.	Check on every relevant request; revoke atomically on takeover.
Private contact	Profile, person type candidate/manager, channel, value, verifiedAt, sharing preference.	Never in discovery response; exact disclosure respects candidate settings.
Profile photo	Profile, slot/cover, private object key, blurred derivative key, MIME/size, moderation status.	<=5 originals total; no publicly reusable original key.
Invitation	Profile, nominated channel, token digest, expiresAt, consumedAt, supersededAt, resend counter.	Single-use atomic consume; 24-hour validity; distinct manager/candidate contact.
Verification case	Subject account/person, document type, status, private evidence refs, reviewer/date/reason, purgeAt.	Manager and candidate cases independent; restricted staff access.
Interest attempt	Pair key, sender profile, receiver profile, status/times, consent version, idempotency key.	One active pending/accepted relationship per pair; retained attempt history.
Connection	Pair key, acceptedAt, endedAt/by/reason, linked accepted request.	Mutual relation separate from current access entitlement.
Shortlist	Owner profile, target profile, createdAt.	Unique pair; private to authorized owner/manager.
Block	Blocker profile, target, createdAt/revokedAt.	Either direction blocks future connection access; retain only approved minimum after deletion.
Report / moderation case	Reporter, target type/ID, category, detail, verified eligibility snapshot, status/outcome, staff notes.	Deduplicate counts; reporter identity not exposed to reported member.
Plan / price version	Tier, term, currency, amountMinor, residence band, effective dates, caps.	Immutable purchased snapshot; configuration changes do not rewrite receipts/history.
Payment submission	Profile, payer, quote, unique reference, private proof, settlement match, status/reviewer/time.	Owner-only approval; unique settlement mapping prevents duplicate reuse.

Record	Essential fields / relationships	Invariants and protection
Entitlement event	Profile, source payment, grant/replace/expire/refund/forfeit event, start/end, tier/caps.	One grant per approved settlement/purchase; append-only history.
Quota ledger	Profile, successful interest ID, timestamp, window keys/counters.	Race-safe reserve; no multiple quota charges for retries.
Consent / disclosure event	Subject, policy version, action, field categories/recipient, time and revocation.	Record what was shared and when without needlessly duplicating raw sensitive values.
Staff role / audit event	Staff identity, role, event, entity, reason, timestamp and correlation ID.	Separate MFA accounts; owner payment role; protected immutable audit.
Notification outbox	Event key, recipient, channel, template version, delivery state, attempts.	Idempotent delivery; no private sender name in unpaid interest email.
Operations / retention job	Signup/upload pause flags, purge batch IDs/results, configuration audit.	Owner-authorized changes; job failure alerts and retry.

Keep all managed profiles scoped by profile ID and all permissions by authenticated account identity. Use row-level security and storage policies from the same versioned migrations. Separate production/staging; synthetic data only in staging. The frontend must never possess service-role keys. Exact SQL schema and endpoint paths are implementation deliverables, not contained in this demo.

12.2 Suggested operation contracts

Operation group	Input / validation	Output / failure behaviour
Profile save / publish / pause	Auth subject, profile ID, version, validated fields, authority/consent version.	Updated public-safe view; conflict for stale version; explicit verification/missing-field errors.
Discover / profile detail	Auth member, authorized scope, filters, cursor; target currently visible.	Allowlisted public-member fields; opaque cursor; separate private-detail authorization.
Send / accept / decline / withdraw	Actor and target profile, request ID, idempotency key, share confirmation.	Stable relation state; deny block/cooldown/limit/expiry/permission conflicts without data leaks.
Private contacts / original photos	Authenticated actor/profile, target, current relation, entitlement and permissions.	Authorized values or denial; no publicly cached response. Re-evaluate after revocation.
Invite / accept / take over	Manager permission or candidate identity, token/channel code, confirmation, version.	Atomic state and access changes; token replay rejected; old sessions lose scope.
Verification upload / review	Own subject, allowed document, upload ticket; reviewer with MFA.	Private case status and reason; no verification badge from simulated result.
Submit / approve payment	Profile quote/reference/proof; owner settlement evidence, idempotency key.	Exactly one activation and audit event; mismatches held for review.
Report / block / moderation	Target/category, verified reporter qualification; authorized staff outcome.	Immediate appropriate protection; thresholds transactional; clear appeal/restoration workflow.
Export / delete	Strongly authenticated subject, ownership scope and confirmation.	Private export job or deletion confirmation; exclude other users' sensitive content and staff evidence.

Use server time consistently. Dates in UI should show local display timezone and unambiguous expiry time; preserve UTC timestamps internally. Request-cap timezone and month definition require owner decision. All write operations should recheck authorization after loading target state rather than trusting stale client booleans. Client errors may be friendly, but sensitive failures must not enumerate hidden accounts or payment details.

12.3 Notification and event coverage

TARGET/PROPOSED event inventory: signup code, recovery code, invitation issued/superseded/expired, candidate accepted/declined/withdrawn, verification pending/approved/rejected, interest received, accepted/declined/withdrawn, connection ended, payment pending/approved/rejected, plan nearing expiry/expired, renewal activated, report received/resolved, auto-hidden/restored, manager revoked/takeover, export ready and deletion acknowledgment. Exact delivery channels and schedule are OPEN except real email/SMS requirements in D5. Do not send identifying interest content to a free recipient. Notifications must not embed private original photos or reusable access URLs. UI badges should derive from durable records, with explicit read/unread semantics if introduced.

13. Current action catalogue and code ownership

The following catalogue covers live network mutations and direct upload mutations. It is intended as a migration checklist. All current permissions are browser-local; replacing each operation with an API call alone is insufficient unless the backend enforces its guards.

Action / helper	Main owner	Rule / side effects / migration treatment
createDemoAccount	matrimony-network.ts	Valid country, member UUID shape, unique actor, name 2-120; creates blank managed draft context. Replace with authenticated creation.
draft	matrimony.ts	Saves arbitrary draft under permission gate; TARGET validate shape and durable save/version.
profile	matrimony.ts + network	Full validation; reset draft; onboarding; consent pending/confirmed; identity change resets trust/access; audit message; birth consent invalidation.
preferences	matrimony.ts + discovery	Validate age/gender/location/options; normalize and save filter object.
contact	network	Validate phone and optional email, trim/cap, save sharingAccepted.
publish / unpublish	network	Free verified completed publication; first timestamp preserved; hide both flags on unpublish.
privacy	network + matrimony	Allowed visibility/legacy photoPrivacy/contactPrivacy/horoscope keys; resume needs eligible publishing prerequisites; horoscope off clears comparisons. Legacy booleans are not separate access gates.
coverVisibility	network	Boolean; cannot enable without cover.
photoUpload	preview/matrimony.tsx	Permission checked in upload handler; FileReader and direct network mutation. Cover replaced or gallery appended up to 4. Not a network switch action.
verificationPhoneStart / Confirm	matrimony-trust.ts	Own seat; 10-minute sample challenge; fixed code; no effective attempts limit.
verificationSubmit	trust	Phone checked; sample only; pending/approved not resubmittable; optional candidate selfie flag.
verificationReview	trust + network	Reviewer only; select owner/person; pending; approve or reasoned reject.

Action / helper	Main owner	Rule / side effects / migration treatment
selfie upload / selfieReview	preview + base domain	Separate pending dataURL verification object; reviewer outcome; rejection reason required by matrimony wrapper. No unified all-account selfie review queue shown in current admin UI.
candidateContact	trust	Manager only, not active; validate contact; invalidate outstanding invitation.
inviteCandidate	trust	Manager, confirmed target contact, not active; 48-hour simulated invitation; clears comparison consents.
joinCandidate / declineInvitation	trust	Unexpired acceptance plus phone/confirmation; decline unpublishes and revokes.
permissions	trust + network	Active candidate toggles manager rights; removing horoscope right clears comparisons.
removeManager	trust	Active candidate confirm; revoke all manager permissions immediately.
revokeCandidateConsent	trust + network	Hide/unpublish, consent declined; end active/pending pair relations and clear comparisons.
restoreCandidateConsent	trust	Previously joined candidate confirm; stays unpublished; does not restore manager or pairs.
requestOwnership	network	Joined candidate only; one request; immediate manager removal/pause; legacy paid completion.
interest / accept	network	Paid eligible sender/recipient rules, pair gates and explicit disclosure confirmation.
decline / withdraw / reopen	network	Recipient decline, sender pending cancellation, recipient-controlled reopening; legacy no cooldown.
revokeConnection	network	Accepted relation only; both access and shortlists removed.
save	network	Toggle shortlist; capacity and eligible/open target enforced for addition.
block / unblock	network	Bilateral discovery exclusion; no automatic relationship resurrection.
report / reportReview	network	One open report per reporter-target; reviewer marks reviewed; no threshold hide.
payment upload	preview	Direct state mutation after permission/file/reference/pending checks; emits pending proof.

Action / helper	Main owner	Rule / side effects / migration treatment
paymentReview	network + base domain	Reviewer, owner profile, pending and decision; ordinary term, boost and ownership branches.
featureProfile	network	Reviewer only; verified/published target; seven days or remove.
horoscope / compatibilityRequest / Consent / Withdraw	network + trust	Legacy birth validation and mutually authorized comparison; RETIRE launch.
deleteProfile	network	Exact DELETE; pair cleanup then reset profile, not authentication account deletion.
viewNetwork	network	Derived directory, interests, anonymized inbox, role view, queues and badges; never reuse as secure backend serializer without redesign.
hasPaid / complete / publisherVerified / eligible	network	Core predicates; documented in chapter 4.
connection / unlocked / coverVisible / blockedCoverVisible	network	Pair and photo access; blocked list can still show target public cover if no reciprocal block and target visible.
seatFor / requirePermission / canReadShared	trust	Current seat mapping and delegated access checks; client roles cannot be trusted in production.
validateContext / validateLocalPreferences / localMatch	discovery	Option normalization and exact contextual matching.
reflection / orderProfiles / overview	discovery	Explainable comparison and sorting, no predictive model.
cleanSocials / heightLabel / AgeWheel	options / fields	Social normalization and presentation helpers; actual form height limit differs from generic helper.

CURRENT actions not exposed as supported live flows: requestConsent/candidateConsent are redirected to invitation flow; request/requestReview and simulated incoming/reply actions are explicitly rejected by network; chat actions explicitly throw no-chat error. Base revoke for historical per-field requests and base state activeChat/messages are legacy baggage. No date-mode route, inbox messaging API, push delivery or real horoscope computation should be inferred from these leftovers.

14. Conflict register and implementation gaps

ID	Current evidence	Target or necessary correction	Priority
G01	Browser Map, global network, seat selector, simulated codes.	Real auth, database and server permission enforcement; remove demo controls in production.	Launch blocker
G02	App LKR 2,990/30 days; marketing three old tiers.	D1 versioned Starter/Premium catalogue and correct marketing; free publish.	Launch blocker
G03	No request counting.	5/day +30/month Starter, 30/day Premium, transactional counter.	Launch blocker
G04	Invite 48h, no token/channel binding/resend cap.	D2 24h single-use plus nominated-channel code and contact inequality.	Launch blocker
G05	Reviewer controls payments.	Owner-only payment rights; separate backup document/report role, MFA.	Launch blocker
G06	Receipt image is enough for approval; in-memory duplicate guard.	Real statement match, settlement uniqueness, transactional idempotency.	Launch blocker
G07	Legacy LKR 1,500 takeover with candidate restricted until approval.	Candidate takeover/manager revocation and term carry-over per D2-D3; do not retain fee without approval.	Policy conflict
G08	3 shortlist tiers, boosts and featuring.	Not specified by new draft; decide retention and approved prices/scope.	Owner decision
G09	Decline/reopen/cancel allow immediate retry or permanent pair block.	Seven-day retry with preserved history; maximum attempts not approved.	Launch blocker
G10	Both-paid unlock, both hidden if one expires.	Draft explicitly hides expired member's contacts; clarify still-paid counterparty and photos.	Owner decision
G11	Single contact object; no per-field candidate disclosure.	Separate manager/candidate contacts, unverified-candidate label, privacy and disclosure audit.	Launch blocker
G12	Trust and selfie systems disagree; UI says NIC only or Selfie reviewed.	Approved document set, truthful three badges and reviewed wording; decide selfie scope.	Launch blocker
G13	No caste-data consent, option or removal-specific event.	Explicit sensitive-field consent, Prefer not to say, withdrawal/removal; legal review.	Launch blocker
G14	Photos/data and all network state reachable by client.	Private originals, authorized derivative delivery, server sender masking.	Launch blocker

ID	Current evidence	Target or necessary correction	Priority
G15	Reports only Open/Reviewed.	Severity thresholds, unique verified reporters, hide/restore and false-report process.	Launch blocker
G16	Only visibility/delete controls.	Engaged/married forfeiture, suspension, multi-profile deletion semantics.	Launch blocker
G17	No retention, audit enforcement, backups or export.	Approved deletion policy, jobs, logs, tested restore/export.	Launch blocker
G18	Horoscope screens/calculation demo retained.	Remove launch routes/actions/copy, retain only importance preference.	Scope correction
G19	Partial Sinhala/Tamil; two locale stores.	Full reviewed English/Sinhala, hide Tamil, unified locale and copy export.	Launch blocker
G20	Unconfirmed public support values, empty app support.	Owner-confirmed channels and dedicated SIM; 48h review capacity and queue pause.	Operational gate
G21	Public policies describe information website only; old URL metadata.	Approved legal operator, product privacy/terms, accurate pricing/help/SEO.	Launch blocker
G22	Fictional member seeds, reviews, activity, receipts and chart.	No invented live members/testimonials; real founding group; synthetic data staging-only.	Launch blocker
G23	No multi-profile account model.	Maximum 3 managed profiles, owner exception workflow, per-profile subscriptions/quotas.	Launch blocker
G24	Inconsistent form/filter country lists; missing separated filter; bio counter/height mismatch.	Normalize reference data and validate same bounds on server and UI.	Functional correction
G25	Contact sharing toggle/visibility affects complete/eligible indirectly; no atomic multi-field save.	Explicit publication/access state changes and transactional saves with clear user consequences.	Functional correction
G26	Legacy privateDetails only controls manager's reading, not candidate's field disclosure choices.	Separate permission to act/read from consent to disclose own data.	Privacy blocker
G27	No expiry warning, renewal window, downgrade block or grace state.	Implement D2 lifecycle; grace stays unapproved.	Launch blocker
G28	Review report data appears beyond reviewer in current view construction.	Strict response allowlists, reporter privacy and staff-only moderation context.	Security blocker

15. Open decisions - do not silently guess

ID	Decision needed	Why it affects implementation
O01	Final sign-off and legal operator; D5 describes unregistered business while source/name references may differ.	Correct contracting party, provider ownership and policy responsibility must be owner-verified.
O02	Calendar-month versus fixed-day terms; timezone/reset and definition of monthly quota.	Expiry arithmetic, month-end/leap-day dates and counters. Current 30 days is not equivalent to a month.
O03	Whether acceptance requires sender still paid; what still-paid party sees after counterpart expiry; photo expiry rules.	Access matrix and stale/pending interests.
O04	Three-day pending-renewal grace and two-resend cap.	Both explicitly recommended only. Default implementation must not claim approval.
O05	Seven-day cooldown anchor/direction; pending cancellation versus accepted withdrawal; counting quota and retry refunds.	Race-safe attempts and anti-harassment logic.
O06	Premium 3-month <-> 6-month changes; same-tier early renewal approval timing; exact lost-day display.	Draft only explicitly names Starter -> Premium upgrade and same-tier last-seven-day renewal.
O07	Candidate daily capabilities before takeover and document gate to republish; takeover fee removal confirmation.	Legacy candidate workspace is much more restricted than a normal member.
O08	Shortlist quotas, boost/featured inclusion, pricing and permission owner.	Existing features not addressed by the new draft.
O09	Badge evidence and whether selfie/liveness exists at launch.	Avoid conflicting or overstated verification labels.
O10	Immediate deletion vs 90-day evidence retention; rejected-case anchor; six-month anchor; proof/backups/log retention.	Draft contains genuine retention ambiguities; legal/accounting sign-off required.
O11	Serious report eligibility; verified reporter meaning; hide photo vs profile; restoration threshold reset/appeal.	Prevent false reports automatically suppressing legitimate members indefinitely.
O12	Pending interests when paused, moderated, suspended, candidate declines, or engaged/married; paid term while merely paused.	Visibility state and entitlement state are separate concerns.
O13	Candidate/manager field-level contact restrictions, default family/income visibility and exposure logging detail.	Current public-member family data may surprise developers expecting it private.
O14	Multi-profile account deletion, invitation collisions and candidate with an existing profile/account.	Avoid destroying unrelated profiles, duplicate candidates or wrong ownership transfer.

ID	Decision needed	Why it affects implementation
O15	Final real payment channels, amounts/fees/FX, short payment/overpayment, payment-proof correction and disputes.	Manual payment still needs a complete settlement/refund workflow.
O16	Request/code/upload/report/invite rate limits and notification timing.	Draft requires limits but does not provide all numeric thresholds; configure and approve them.
O17	Whether retain shared-values percentage despite No compatibility scores copy.	Keep product language honest and algorithm interpretable.
O18	Trusted support contacts, review coverage, response targets and owner unavailability plan.	Single payment approver is an operational bottleneck.
O19	Authoritative legal language and review completion for Sinhala.	Consent/policy versioning and translations cannot be left partly implemented.
O20	Anonymous access to preview versus future member-only directory and production launch approval.	Public demo authorization does not authorize collecting live sensitive data.

These are unresolved specifications, not requests that block delivery of this handbook. Developer should track decisions with owner, date, approved value and affected tests before implementing the relevant branch.

16. Developer acceptance-test catalogue

These are REQUIRED FUTURE ACCEPTANCE SCENARIOS, not claimed passes. Test with real separate staging accounts: anonymous, member A/B, free verified member, candidate, manager, revoked manager, backup reviewer and owner. Inspect API bodies and file responses, not only rendered UI. Add a controlled clock for time boundaries and concurrent clients for races.

ID	Scenario / conditions	Expected result
A01	Register with email and with supported local/overseas phone; real code delivery.	Correct account, channel-bound verification; no fixed demo code; messages arrive.
A02	Invalid/expired/replayed code, excessive attempts/resends; login and recovery abuse.	Safe rejection and enforced rate limit; no credentials or code in logs.
A03	Logout, reload, new device, password reset.	Real session policy holds; persisted profile survives; revoked sessions lose access.
A04	Same account creates multiple managed profiles; concurrent fourth creation.	First three allowed; fourth denied unless recorded owner exception; separate plans and quotas.
A05	Two members edit simultaneously.	Version conflict or safe field merge; no silent overwrite or partial profile/contact update.
P01	Required fields missing, 17-year-old, malformed age/height/phone/email, overlength bio.	Server rejects; usable field errors; no accidental publication.

ID	Scenario / conditions	Expected result
P02	Self-managed phone complete but document pending; vice versa.	Cannot publish until both approved conditions.
P03	Verified complete unpaid self-managed and managed profiles.	Free publication allowed; browse/receive available; send/accept locked.
P04	Manager document approved; candidate unconfirmed.	Manager badge only; candidate confirmation/identity not fabricated.
P05	NIC/passport/driving-licence submission, reject with reason, resubmit.	Independent case history and correct status; no manager selfie requirement.
P06	Identity/contact changes after verification.	Approved re-verification/restriction policy applies; no stale badge.
P07	Ineligible/unpublished/paused/blocked/deleted target in discovery, search and deep links.	Target unavailable under approved policy, with no private data leakage.
P08	Five photo slots, sixth upload, cover switch, replacing cover.	Maximum enforced transactionally, approved visibility intact; old files cleaned appropriately.
P09	Fake MIME, malformed image/PDF, oversize and unauthorized object path.	Safe rejection; no execution or unintended storage access.
P10	Anonymous attempts cover/gallery download and profile enumeration.	No member photos or identifying directory data delivered.
I01	Invite candidate to manager's own normalized email/phone.	Rejected; whitespace/case variants cannot bypass.
I02	Invite at 23:59 vs exact 24-hour expiry, resend invalidates previous link.	Valid before deadline only; previous token cannot be used.
I03	Two clients consume same invitation; replay after acceptance.	One atomic acceptance; second rejected/idempotent without new access.
I04	Candidate channel proof belongs to someone else or token changed to other profile.	No acceptance, no profile disclosure beyond authorized invitation context.
I05	Candidate accepts without later identity review.	Confirmation recorded separately; identity badge absent.
I06	Candidate declines/withdraws; manager tries republish directly by API.	Takedown enforced; manager cannot override candidate objection.
I07	Candidate disables edit/interests/privateDetails permission one at a time.	Affected manager API and file access immediately denied; unrelated profiles unaffected.
I08	Takeover with paid term; old manager uses old session and stored URL.	Paid expiry preserved, manager loses affected access immediately, no payment gate unless separately approved.

ID	Scenario / conditions	Expected result
I09	Restore candidate consent after takedown.	Remains hidden until explicit publication; revoked manager/ended relationships not restored.
D01	All filters combined; missing optional data; Unicode/Sinhala search; empty results.	Correct intersection and honest no-match/reset behaviour.
D02	Country/district change and multi-select, country outside small demo list.	No stale region, invalid list conflict or dropped valid country.
D03	Sorted ties, newest publication, values reflection and percentage.	Deterministic order, documented formula, no unsupported compatibility claim.
D04	Shortlist at capacity, expired plan, unavailable target.	Approved capacity policy, safe removing, no secret saved target data.
R01	Paid sender sends to free verified recipient.	Receiver gets nonidentifying preview; no sender ID/name/original photo in API or email.
R02	Starter requests 1-5 daily; sixth; 30th monthly; 31st.	Allow limits, deny excess; boundary reset follows approved timezone/window.
R03	Premium 30th and 31st daily, including two simultaneous final-slot sends.	At most 30 successful counted sends; no race overrun.
R04	Retry identical send after network timeout.	Same result, one request and one quota charge.
R05	Recipient unpaid tries accept by direct API.	Denied without identifying sender or revealing contacts.
R06	Both qualifying parties accept; supplied photos/contact/socials.	Authorized fields only, according to candidate preferences and connection.
R07	Decline; send at 6d23h59m and at 7d boundary.	Cooldown enforced then allowed according to approved direction/attempt policy.
R08	Withdraw pending versus end accepted; crossed requests.	Approved state machine, history and cooldown; no duplicated connection.
R09	Block, unblock, reciprocal block, stale profile sheet.	Immediate future-access denial; no restored connection merely from unblock.
R10	Plan expires during open profile/photo view and renewal.	New reads denied according to final matrix; connection retained and appropriately restored on renewal.
R11	Photo cover off but gallery original URLs guessed or obtained earlier.	Unauthorized new fetch denied; blur is derivative, not CSS-hidden original.
R12	Unconfirmed candidate details shared by manager.	Required attestation, label, candidate restriction/takedown and disclosure audit per signed-off policy.

ID	Scenario / conditions	Expected result
M01	All six price cells, configurable new price version and old pending quote.	Correct minor units/currency; historical price not overwritten.
M02	Residence/payment mismatch, Sri Lankan NIC but overseas residence.	Flag for owner review, not automatic rejection.
M03	Proof submission without real settled transfer, wrong amount/reference or reused transaction.	No activation; investigation/rejection records.
M04	Backup reviewer requests payment API/file/list directly.	Denied by backend/storage policy, not merely menu hidden.
M05	Two simultaneous approval calls, retry after timeout, second receipt for same settlement.	Exactly one entitlement grant; auditable idempotent outcome.
M06	Rejected proof then corrected submission; multiple profiles' pending proofs.	Every proof visible to owner, reason preserved, correct profile activated.
M07	Upgrade Starter to Premium with unused time.	Exact forfeiture warning acknowledged; one replacement term from approved date.
M08	Active downgrade, same-tier renewal earlier than 7 days, exact 7-day boundary.	Enforce approved window; explicit denial reason.
M09	Month-end, leap-year, expired plan approval and optional grace off.	Agreed term arithmetic; no accidental automatic renewal/grace.
M10	Refund exception and dispute/suspension; engaged/married finish.	Approved entitlement consequence, confirmation and immutable audit.
S01	Serious single report; other category from 1, 2 and 3 distinct verified reporters.	Auto-hide at correct threshold; repeated same reporter does not inflate count.
S02	Staff restores wrongly hidden content, repeated false reporter, minors category.	Recorded outcome, approved threshold reset and operational escalation.
S03	Reporter identity/notes queried by reported member or unrelated member.	Not disclosed.
S04	Staff without second factor calls reviewer endpoint.	Backend denies privileged operation.
S05	Backup leaves; owner loses MFA device.	Immediate staff revocation and documented tested recovery path.
S06	Owner pauses signup or document intake.	Intended intake blocked with explanation; existing-member effect follows explicit policy.
X01	Document reaches approved purge deadline; purge job fails mid-batch and retries.	Correct file deletion, auditable retry, no accidental metadata/policy loss.
X02	Account deletion with managed profiles, private files, contacts and retained records.	Immediate disappearance; approved erasure and minimized retention; no orphan accessible files.

ID	Scenario / conditions	Expected result
X03	Restore backup after deletion.	Database and files restored consistently; deletions reapplied; no resurrected public profile.
X04	Export requested by candidate, manager and revoked manager.	Own authorized data only; no staff-private reports, other candidates or secret files.
U01	360/390/768/1440px, iOS Safari, Android Chrome, desktop browsers.	No clipped controls/overlays, usable scrolling/upload, legible cards and consistent theme.
U02	Keyboard, screen reader, zoom, reduced motion and slow/flaky connection.	Focus retained/restored, errors announced, operation retries safe, no trapped modal or false success.
U03	English/Sinhala including errors/consents/emails; Tamil hidden.	Full reviewed coverage; original member text preserved; authoritative legal version clear.
U04	Marketing Join from all pages; deep link; 404; canonical/sitemap/robots.	Correct deployed routes and accurate launch indexing policy.
U05	Production bundle/database scan for samples and legacy features.	No sample account switcher, fixed codes, fictional members/testimonials, horoscope results or chat.
U06	Safe load test with synthetic records and restoration drill.	Measured service behaviour against owner-approved target; monitoring and rollback demonstrated.

17. Build sequence, handover and operational gates

17.1 Staged implementation from the supplied draft

Stage	Required work and evidence
0 - Baseline and rule audit	Run existing demo/build/tests in reproducible environment, inventory routes/simulations/dependencies, tag rollback, record every rule mismatch; do not change rules yet. This handbook supports the audit but does not replace executing the baseline.
1 - Foundation	Introduce Vite/TypeScript incrementally, retain public HTML and styling; staging Supabase schema/migrations/RLS/storage; separate production; synthetic test accounts and real permission tests.
2 - Accounts and verification	Real auth/recovery, profile roles, 24h invitations, takeover, badges, manager capacity, secure documents and deletion job, separate staff MFA/permissions.
3 - Requests and privacy	Real discovery/relations, quotas, seven-day cooldown, server sender masking and photo derivatives, expiry gates, report thresholds, pause/finish and concurrency.
4 - Payment and email	Versioned catalogue, references, owner reconciliation, idempotent activation, upgrades/renewal/expiry, refund log, real email and Turnstile verification.
5 - Content and quality	Replace outdated public copy; remove fictional claims; English/Sinhala review export; rate limits, headers, intake pause, deletion/export, accessibility/SEO.
6 - Harden and hand over	Full staging acceptance tests, browser/slow-network checks, load test, database+files restore drill, source/migrations/env/deployment/rollback/cost guide and honest blockers.

D6 working rules say implement one stage at a time, commit/tag, update BUILD-PROGRESS.md with actual test evidence and wait for owner's continue; stop after three failed attempts on a test/fix and report blocker. Warn before high-credit steps. Do not rewrite/delete large existing files without asking. Keep secrets in the designated secret manager, not code/logs/chat. Do not introduce a second authentication system or unneeded paid service. Accounts must belong to owner/business, developer as collaborator. The prompt's Replit Secrets instruction applies if executing that Replit workflow; any different hosting environment needs an explicitly documented equivalent secure secret store.

17.2 Developer handover package

Deliver maintainable source and lockfile; versioned migrations and rollback constraints; staging URL; environment-variable names without secrets; account/service ownership list; configured plan/rate-limit reference; complete acceptance evidence; deployment/rollback instructions; data/file export procedure; backup/restore evidence; retention-job schedule and monitoring; staff runbooks; reviewed English/Sinhala copy export; monthly operating-cost estimate tied to verified current usage/pricing; unresolved decisions and security/legal findings. This documentation is the functional handover, not those completed implementation assets.

17.3 Launch gates already present in the owner draft

Independent developer security review and lawyer sign-off precede explicit production launch approval. Review items include manager-declared age, unconfirmed-candidate disclosure, sensitive caste/religion data, retention and deletion, English/Sinhala terms/refunds/privacy, minors handling and applicable data-protection duties. Accountant confirms record-retention and payment/tax arrangements. D5 records a sub-USD-500 budget and unregistered/personal-account concerns; treat these as statements in the draft requiring owner confirmation, not newly verified facts. This report does not provide legal/tax approval or validate receiving providers.

The source's public preview remains useful for developer walkthroughs. It must not be used to collect real identity documents, credentials or transfers. Production launch is a separate milestone from making a demonstration URL public.

18. Source map, glossary and coverage index

18.1 Source map

Path	Responsibility / chapters
product/preview/entry.tsx	Account-entry mounting, React lifecycle, landing return; chapters 2, 5.
product/app/matrimony/account-entry.ts	Locale/signup/login/code/recovery/sample login; 5, 10.
product/preview/matrimony.tsx	Main screens, wizard, handlers, direct uploads, review queues and overlays; 3-11, 13.
product/lib/domain.ts	Seed people, base state/actions, historical validation and ordinary payment/selfie mutations; 2, 5, 9, 11.
product/lib/matrimony.ts	Current profile model, plan constants, profile/preferences validation and legacy actions; 5, 9, 13.
product/lib/matrimony-network.ts	Pair transitions, derived views, entitlement/eligibility, publishing, report/block, transfer/promotions; 4, 6-9, 13.
product/lib/matrimony-trust.ts	Verification, invitation, permissions, badges, horoscope readiness; 4, 6, 11.
product/lib/matrimony-discovery.ts	Location/context lists, preferences, matching/reflection/order; 5, 7.
product/lib/matrimony-profile-options.ts	Hobbies, horoscope importance, social platforms and URL cleaning; 5.
product/lib/profile-options.ts / country-options.ts	Education, jobs, generic helpers, country list; 5, 7.
product/lib/site-locale.ts	Partial text localization and browser storage; 10.
product/app/matrimony/profile-fields.tsx / profile-extras.tsx	Age, languages, family, income, review summary, hobbies and socials; 5.
product/app/matrimony/profile-detail-content.tsx	Photo carousel, About/Family/Horoscope/Contact tabs and locked states; 4, 7, 11.
product/app/matrimony/trust-workspace.tsx / horoscope-workspace.tsx	Candidate/manager UI and legacy comparison flow; 6, 11.
product/app/matrimony/location-filter.tsx / promotion-shelf.tsx	Multi-select popover and responsive featured carousel; 7.

Path	Responsibility / chapters
product/app/matrimony/contact-us.tsx / product/lib/support-channels.ts	App channel configuration; 10.
product/app/matrimony/responsive-section.tsx / product/app/shared/*	Collapsible/help/language UI and icons.
product/components/ui/*	Radix-backed dialogs, sheets, selects, tabs, alert dialogs, popovers, checkbox, switch, progress, table, buttons and toast support.
product/preview/*.css / product/app/design-system.css	Member styles, theme, contrast and combined overrides.
website/src/pages/* / partials/*	All marketing pages and shared navigation/footer/dialogs; 11.
website/src/scripts/* / styles/*	Page and shared interactions, resource/pricing carousels, motion and styles; 11.
website/site.config.json	Site origin, indexable flag, registration destination, support/social defaults.
scripts/build.mjs / scripts/serve.mjs / website/scripts/build.py	Build and local static serving.
tests/*.mjs / docs/TEST-RESULTS.txt	Existing tests and historical run output; not production security tests.
docs/ENGINEERING-HANDOVER.md / docs/bundle-inputs.json / docs/licenses/*	Historical architecture, actual bundle inputs and dependency licences.
dist/*	Exact static deployment artifact; edit source then rebuild.

18.2 Existing test-suite map

Test file	Subject covered in supplied suite
integration.mjs	23 HTML pages, asset/link existence, Join registration route and no dating bundle; launches component suites.
join-links.mjs	DOM click navigation for all 24 Join controls.
matrimony-accounts.mjs	Entry layout/theme, signup validation, distinct profiles, OTP, logout/login/recovery.
matrimony-publish.mjs	Self/managed wizard, required phone/profile fields, payment and identity/publication gates.
trust-edit-ui.mjs	Verification order/badges, phone-only candidate acceptance, quick edits, height/menu.
access-policy.mjs	Free publishing, 3/20 shortlist gates, anonymous inbox, photo/contact masking and invitations.
invitation-policy.mjs	Phone-before-evidence, optional identity, expiry and height bounds.
delegation-transfer.mjs	Candidate limitations, manager permissions, birth readiness and paid legacy takeover.
oct09-policy.mjs	Additional profile privacy, hobbies/socials, boost/featured and safety logic.
v7-policy.mjs	Public-member family/income, blocked-list cover rules and social username normalization.

Do not preserve a test merely because it passes if its expected behaviour conflicts with the approved new policy. Keep historical regression coverage, mark intentionally superseded expectations, then add target acceptance coverage with real accounts and database/storage rules.

18.3 Glossary

Term	Meaning
Account	Login identity; can own/manage profiles. The demo mostly conflates account and profile.
Candidate	Adult represented by the matrimonial profile.
Manager	Authorized person managing a candidate's profile; not automatically the candidate.
Publisher	Person whose phone/document verification enables publication under the chosen role.
Published / eligible	Published is stored intent; eligible is current derived discoverability after all gates.
Interest / connection	Interest is an introduction request; connection is mutually accepted relationship, not chat.
Entitlement	Current paid feature access on a specific profile, derived from approved payment/lifecycle.
Permission	Which actions a manager or staff user may take; distinct from consent to share data.
Consent / disclosure	Agreement to publish/manage/share and actual data release; each needs clear scope/history.
RLS	Database row-level security restricting which records each authenticated identity may read/change.
Idempotent	Repeating the same operation does not create a second business effect.
Outbox	Durable queued events for reliable notifications after a committed transaction.
Blurred derivative	Separate non-original image file for unauthorized viewers; CSS blur is insufficient.

18.4 Feature coverage cross-reference

Entry/auth -> 5.1; onboarding/fields -> 5.2-5.3; publishing -> 4.3 and 6.1; manager/candidate -> 4 and 6; badges -> 6.1; invitations -> 6.2; takeover -> 6.3; discovery/filtering -> 7.1-7.2; algorithms/compare -> 7.3; shortlist/promotions -> 7.4; requests/cooldown -> 8.1-8.2; photos/contact/privacy -> 4.4 and 8.3; report/block/moderation -> 8.4; payments/plans -> 9; staff -> 10.1; retention/export -> 10.2 and 12; support/localization -> 10.3-10.4; public website -> 11.1-11.3; legacy horoscope -> 11.4; source actions -> 13; gaps/decisions -> 14-15; acceptance -> 16; build handover -> 17.

Appendix A. Original owner decision document

The following seven pages reproduce the supplied Owner Decisions and Replit Prompts draft without changing its wording. Its original printed page numbers are D1-D7 in this handbook's references. The provisional status and recommended-but-not-decided labels remain in force. For contradictions within that draft, use the open-decision register rather than assuming this handbook silently resolves them.

Favorite Hearts: Owner Decisions and Replit Prompts

Draft v1, 19 October 2026. Every rule below is a provisional default until the owner, a lawyer and an accountant have approved it. Items marked **[RECOMMENDED, NOT YET DECIDED]** are suggestions, not decisions.

How to use this document

1. Copy Parts 1 and 2 into the project as docs/OWNER-DECISIONS.md. It overrides anything that conflicts with it in the demo, the pricing page, the FAQs and the terms.
2. Give Part 2 to your lawyer, accountant and developer as well.
3. Paste Part 3 into Replit one stage at a time, never all at once.

Part 1: Owner decisions

1. Business model

- Matrimony only. No dating, no chat. Horoscope features are out of scope for launch (the "how important is horoscope matching" preference field stays).
- Creating and publishing a profile is **free**, once verification is complete (see section 5).
- **Payment unlocks** sending requests, seeing who sent interest, and accepting requests.
- Unpaid verified members can browse all published profiles and receive interests, but sender identities stay blurred, they cannot send requests, and they see no contact details.
- The old pricing page, FAQ text and terms that say a paid subscription is needed to publish are **wrong and must be replaced**. The old Essential/Signature/Premier tiers and their human services (profile presentation help, personal profile review, priority support, onboarding guidance) are **dropped**.

2. Plans and prices

Plan	Length	Limits	Local price	Diaspora price
Starter	1 month	5 requests/day, 30/month	LKR 3,000	USD 20
Premium	3 months	"Unlimited", fair-use cap 30/day	LKR 8,500	USD 55
Premium	6 months	"Unlimited", fair-use cap 30/day	LKR 15,000	USD 100

- Store money in minor units with currency and a price version. Prices must be configurable, never hard-coded.
- Advertise Premium as "unlimited requests (fair use applies)" and state the real daily cap in the terms.
- **Who gets which price:** the member selects their country of residence. Staff compare it with the payment source (local LKR bank transfer vs international transfer, Wise or PayPal) and with the verified document. A Sri Lankan NIC does not show residence, so any mismatch is a **flag for staff review, not an automatic rejection**.
- **Each profile has its own plan** and its own limits. A manager running several profiles buys a plan per profile.

3. Plan rules

- No automatic renewal. Payment is manual (see section 9).

- **Replacing a plan:** a new plan replaces the current one immediately, **but only as an upgrade** (Starter to Premium). Downgrades are blocked while a plan is active. Unused days on the old plan are lost, and the member must see a clear warning stating exactly what they lose before paying.
- **Renewing the same tier** is allowed only in the last 7 days of the current plan. The new term is counted from the **approval date**, even if the old plan has already expired.
- When a plan expires, the member can no longer see **anyone's** contact details or social handles, including existing connections. Connections stay on record, and details reappear on renewal.
- Show members a clear expiry warning before it happens, with the date and what will be hidden.
- **[RECOMMENDED, NOT YET DECIDED]** Keep access active for up to 3 days while a renewal with proof is pending, so slow staff review does not penalise a member who paid on time.

4. Requests and connections

- A request becomes a connection only when **both sides accept**. If someone declines, nothing unlocks.
- A connected member can withdraw at any time. Withdrawing removes both sides' access to each other's details from then on. Log every withdrawal.
- After a decline or withdrawal, the same person may send a new request after **7 days**.
- **[RECOMMENDED, NOT YET DECIDED]** Cap re-sends at 2 attempts per pair, and the receiver can always block.
- After both accept, **all contact details and social handles are shared by default** (the manager's and the candidate's). The candidate can restrict this in privacy settings.
- This applies equally to profiles whose candidate has **not** confirmed yet, so unconfirmed candidates have their details shared on the manager's word. This is a **high-risk decision**: the lawyer must approve it, the guardian must confirm in the terms that they have the candidate's permission, the log must record exactly what was shared and when, and the candidate gets a one-click takedown once they appear.
- A candidate's phone number on a guardian-managed profile does not need to be verified, but it must be labelled "not verified by candidate" until the candidate confirms.
- Sender blur is enforced **on the server**. The browser never receives the sender's identity before payment, and styling-only blur is not acceptable.

5. Profiles, managers and verification

Self-managed profile. Published only after **both**: staff approve an identity document, and the member verifies their phone by SMS code.

Accepted documents: NIC, passport, or driving licence. Badge wording must say "identity document reviewed", never "government verified".

Signup: by SMS or by email, the member's choice.

Guardian-managed profile:

- A manager may publish for a candidate. Only the **manager's** identity document is reviewed, and the manager verifies their own phone.
- Each manager may run **up to 3 profiles**. More only with the owner's approval. Agencies are not supported in v1.
- The manager invites the candidate by link. The link is **single-use**, expires in **24 hours**, and requires a code sent to the phone or email the manager entered for the candidate. The candidate contact must differ from the manager's. Sending a new link cancels the old one, with a limit on resends.
- The candidate can accept and confirm, verify their identity later, set privacy options, decline, or **take over** the profile by removing the manager.

- On takeover, the manager's **paid time carries over** to the candidate until it expires. The manager loses all access to that profile immediately, including requests, connections and contact details. This needs its own test.
- **Three badges, each meaning exactly one thing:** Manager verified, Candidate confirmed, Candidate identity verified.
- **Age:** minimum 18. For guardian-managed profiles age is enforced **by the manager's declaration only**, backed by the terms and the report system. This is **HIGH RISK**: nothing technical stops a minor being listed. The lawyer must approve this before launch.
- **[RECOMMENDED, NOT YET DECIDED]** Ask the candidate to confirm their date of birth when they join via the invite link.

6. Profile fields and sensitive data

- **Religion, marital status:** kept as in the demo, optional where possible.
- **Caste:** optional, shown on the profile if the member chooses, and others can filter by it. Requires explicit consent when entered, a "prefer not to say" option, never visible to anonymous visitors, removable any time. Likely special-category data: lawyer to confirm.
- **Income:** optional, entered as a range, shown on the profile, labelled "self-declared".
- Photos: up to **5 per profile**, one of them the cover photo.

7. Photos, reporting and moderation

- The member can switch the **cover photo** on or off for others. The other photos stay **blurred until both sides accept**.
- The blur is real: the server sends a separate blurred image to anyone not yet allowed, and originals stay in private storage.
- No photo is visible to anonymous visitors.
- Photos appear immediately. Staff review only reported photos. During document review, the reviewer may glance at the cover photo at no extra cost.
- **Reports:** serious categories (explicit content, minors, threats, scam) hide the content after **1 report**. All others hide after **3 reports from different verified members**. Staff review every auto-hide quickly, and wrongly hidden content is restored. Repeated false reporting has consequences.
- Involving minors: staff need a written procedure, and the lawyer advises on reporting obligations.
- **Pause and finish:** a member can pause or hide their profile at any time. A member can also mark themselves "engaged or married", which hides the profile and ends the plan. Warn them clearly that remaining plan time is forfeited.

8. Data retention and deletion

- **Verification documents:** kept **90 days after approval**, then deleted automatically. Rejected documents and documents of members who delete their account follow the same limit. A scheduled job does this, and every run is logged.
- **After approval keep only:** document type, reviewer, date and decision.
- **Account deletion:** the profile disappears immediately. Profile text, photos, contact details, social handles and documents are deleted. A limited set of records is kept for **6 months**: payment records, reports and blocks, the audit log of staff actions, and a scrambled form of email and phone to stop banned users re-registering.

- The accountant must confirm whether payment records need to be kept longer than 6 months. Keep them separate from member profiles, with no photos or documents.
- The privacy policy must list exactly what is kept and for how long, and state that details already shared with connections cannot be recalled.
- Never accept documents by WhatsApp or email. Members upload only through the secure form.

9. Payments and refunds

- Manual bank transfer. **Local:** LKR transfer. **Diaspora:** international transfer into a USD account (SWIFT), or manual Wise/PayPal-style payment, with proof uploaded.
- Each member gets a **unique payment reference**. A plan activates only after staff match the payment to the reference in the **actual bank or Wise statement**, not just the uploaded image.
- **Only the owner approves payments.** The backup reviewer has no access to payment screens. This is enforced by permissions in the database, not by hidden buttons.
- Approval must be transactional and idempotent. A duplicate approval can never activate a plan twice.
- PayPal-style payments can be disputed later. The terms must say what happens to the plan if that occurs.
- **Refunds:** none once a plan is activated, **except** duplicate payments, mistaken payments, and failures on our side. Say this on the pricing page and at the payment step, and have the member confirm they read it. If a member is suspended for breaking the rules, remaining time is lost, and the terms say so.
- Do not invent bank details. The owner supplies real ones.

10. Staff, support and launch

- Reviewers: the owner plus **one trusted backup**. Each has a separate account with two-step login. The backup signs a confidentiality agreement and access is removed immediately if they leave.
- The backup handles documents and reports, **not payments**.
- Promise review of documents and payments within **48 hours** at launch, and tighten it only after real volume shows it is realistic.
- The admin side needs a control to **pause new signups or document submissions** if the review queue is overwhelmed.
- Plan a recovery path for the owner's own admin account if the phone with two-step login is lost.
- **Support channels:** email, WhatsApp (WhatsApp Business app, two-step verification on) and phone, all on a **new dedicated SIM**. The site lists the official numbers and states that staff never ask for passwords or verification codes.
- **Launch:** open to everyone from day one. The site will look empty at first. **Fake profiles or invented testimonials are forbidden.** Plan a real founding group before opening if possible, and load-test before launch.
- **Languages:** English and Sinhala at launch. **Tamil is hidden** (not deleted) until fully translated. A trusted native Sinhala speaker reviews all Sinhala text before launch. Export all text to a spreadsheet (English and Sinhala columns) so the reviewer never touches code. Terms and privacy wording in Sinhala also go to the lawyer, and one language is named the official version.

Part 2: Risks and items needing a human

Lawyer must review before launch

1 Age rule for guardian-managed profiles (manager's declaration only).

2. Default sharing of an unconfirmed candidate's details after mutual acceptance.
3. Retention periods (90 days documents, 6 months other records) and the deletion list.
4. Caste and religion as sensitive data, and consent wording.
5. Terms, privacy policy and refund terms, in English and Sinhala.
6. Obligations if content involving a minor is reported.
7. Whether Sri Lanka's data protection law applies and what registration or duties follow.

Accountant must confirm

1. How long payment records must be kept.
2. Tax treatment of receiving member payments, especially into a personal account.

Business risks to decide knowingly

- **Business is not registered** and registration is planned after launch. Terms and policies must name a legal operator, service accounts and contracts will need transferring later, and the owner is personally liable until then.
- **Payments go into a personal bank account.** This can cause tax and compliance problems, and banks may question many incoming transfers. Wise and PayPal personal accounts often forbid business use. Check each provider's terms and confirm they can receive these payments.
- **Budget under USD 500** for building and reviewing, against an open day-one launch holding identity documents, private photos and payment proofs. The owner ranked priorities: (1) independent developer security review, (2) enough Replit credits, (3) developer account setup, (4) lawyer review. Recommendation: move the lawyer above account setup, at least for a short review of the lawyer points above.
- **Single payment approver.** If the owner is unavailable, paid members wait.
- **Account ownership rule:** every account (Supabase, Cloudflare, GitHub, email provider, domain) is created under the owner's email or business with the owner as owner. The developer is added as a collaborator and removed when the job ends.

Developer review checklist (independent, before launch)

- Database access rules tested with real separate accounts: anonymous, member A, member B, candidate, manager, revoked manager, reviewer, owner.
- The blur and the sender-hiding cannot be bypassed from the browser.
- Contact details and private photos are never sent before mutual acceptance.
- Blocks, withdrawals, expiry and takeover remove future access immediately.
- The backup reviewer cannot open payment screens, even by calling the API directly.
- Payment approval is idempotent under simultaneous clicks.
- Upload spoofing, oversize files and unauthorised file paths fail safely.
- Admin two-step login is enforced by the backend, not only the interface.
- Invite links are single-use, expire in 24 hours, and cannot be replayed.
- Rate limits on sign-in, codes, requests, invitations, reports and uploads.
- Document deletion at 90 days actually runs, and backups restore both the database and the files.
- Real emails and real SMS arrive, including to Sri Lankan and overseas numbers.

Part 3: Replit prompts

Rules for every stage (paste at the start of each session)

```
You are building Favorite Hearts, a Sri Lankan matrimony platform. I am not technical.
Read docs/OWNER-DECISIONS.md first. It overrides any conflicting statement in the demo,
the pricing page, the FAQ, the terms and the existing docs. Keep its rules as provisional
defaults. Do not invent or silently change business rules, prices or legal text.

WORKING RULES
- Do ONLY the stage below. When finished, STOP, commit to Git with a tag, update
  docs/BUILD-PROGRESS.md with pasted test output as evidence, and wait for my "continue".
- If a test or fix fails 3 times, stop and tell me what is blocked. Warn me before any
  step likely to use a lot of credits.
- Never delete or rewrite large existing files without asking first.
- Keep all secrets in the Replit Secrets panel only. Never in code, logs or chat.
- Never claim something passed unless you ran it and show the output.
- Do not add a Replit database, a second login system, or unneeded paid services.
- All provider accounts are owned by me or my business. Document how to export everything.
- Never show a verification badge for a simulated check. If a service is unavailable,
  mark that integration BLOCKED instead of faking success.
```

Stage 0: Baseline and rule audit

```
STAGE 0 ONLY. Run the existing demo, build and tests. Record routes, simulations,
dependencies and a task checklist in docs/BUILD-PROGRESS.md. Tag a rollback point.
Then produce docs/RULE-AUDIT.md: list every place where the demo, the pricing page,
the FAQ, the terms or the help pages conflict with docs/OWNER-DECISIONS.md
(for example the old Essential/Signature/Premier plans, USD 29/49/69 prices, and any
statement that payment is needed to publish). Do not fix anything yet. Stop and report.
```

Stage 1: Foundation and database design

```
STAGE 1 ONLY. Introduce Vite and TypeScript incrementally for the member app, keeping the
public HTML pages and styling. Design versioned SQL migrations for Supabase (staging only,
synthetic data only): accounts, profiles, manager memberships, private contacts, photos,
invitations, interests and connections, shortlist, blocks and reports, plans and price
versions, payment submissions, entitlement events, verification cases, roles, audit events,
and a notification outbox. Keep contacts, documents and private photos separate from
discoverable profile fields. Write row-level access rules and storage rules in the same
migrations. Deny by default. Create staging and production as separate projects.
Test the rules with several real test accounts, not only the privileged key. Stop and report.
```

Stage 2: Accounts and verification

```
STAGE 2 ONLY. Replace the simulated signup, codes, login and recovery with real Supabase
authentication (email or SMS signup). Implement self-managed and guardian-managed access,
the 24-hour single-use invite link plus code, candidate takeover, the three badges, and
the 3-profiles-per-manager limit. Implement the document upload flow (NIC, passport or
driving licence) with staff review, the 90-day automatic deletion job with logging, and
reviewer roles with two-step login. The backup reviewer must NOT have payment permissions,
enforced in the database. No demo code or account switcher may work in production.
Stop and report.
```

Stage 3: Requests, connections and privacy

```
STAGE 3 ONLY. Connect discovery, interests, accept, decline, withdraw, block and report
to authenticated backend logic. Enforce on the server: mutual acceptance, sender blur
(the browser must never receive a sender's identity before payment), the 7-day re-send rule,
Starter limits (5/day, 30/month) and the Premium cap (30/day), the cover-photo toggle,
the server-side blurred photos, expiry hiding contact details for the expired member, and
report thresholds (1 report for serious categories, 3 from different verified members
otherwise). Add withdraw, pause, and "engaged or married" with its warning. Make
concurrent requests consistent. Stop and report with test evidence.
```

Stage 4: Plans, payments and email

```
STAGE 4 ONLY. Implement the three plans and LKR/USD prices from docs/OWNER-DECISIONS.md
as configurable, versioned values. Implement manual payment: unique payment reference,
proof upload, owner-only approval, idempotent activation that cannot double-activate,
the replace/renew/upgrade rules, expiry warnings, takeover carry-over, refund exceptions
recorded, and an immutable audit trail. Use real bank details supplied by me, never
invented ones. Connect Resend for email and a Turnstile server-side check. Show the
pricing-tier mismatch flag to the reviewer. Stop and report.
```

Stage 5: Content, safety and quality

```
STAGE 5 ONLY. Replace the pricing page, FAQs, terms, privacy and help text with versions
that match docs/OWNER-DECISIONS.md and list every page changed. Remove or flag all
fictional testimonials and unverified claims. Implement English and Sinhala with Tamil
hidden, and export all text to a spreadsheet for my reviewer. Add rate limits, security
headers, the admin control to pause signups, deletion with the 6-month retention list,
data export, accessibility fixes, and SEO basics (unique titles and descriptions,
canonical links, social preview tags, sitemap check). Stop and report.
```

Stage 6: Test, harden and hand over

```
STAGE 6 ONLY. Run the full acceptance checklist in Part 2 of docs/OWNER-DECISIONS.md
against staging. Test desktop and mobile browsers, keyboard use, uploads and slow
connections. Run a backup and restore drill covering both database and files. Run a
safe load test with synthetic data. Deliver: staging URL, source, migrations, tests,
environment guide, deployment and rollback instructions, monthly operating costs, and an
honest launch-readiness report listing every open blocker. Do NOT call the product
launch-ready. I will give explicit approval for public launch only after the independent
security review and the lawyer's sign-off.
```